

Vibe coding enterprise data protection

Boundaries, not prompts, contain vibe-coded leaks

Data leaks from vibe-coded applications and AI coding agents almost never come from clever-but-wrong generated code; they come from four structural conditions that the generated code cannot see and the builder does not know exist. In 20 incidents and seven large-scale scans verified against primary sources for this paper, the demonstrated capability was row-level read or write through an internet-reachable data API with missing or inverted authorisation, unauthenticated publishing by default, platform-side authorisation bugs, or an agent holding an over-scoped credential that reached production and its backups together. The original research report this paper reviews had the thesis right and roughly thirty specifics wrong or over-compressed; the independent audit that followed caught most of the headline errors but missed at least six, including that Supabase's 30 October 2026 grant change leaves RPC EXECUTE defaults untouched, that the certificate-transparency blind spot it listed as an open question is now empirically verified for all five builder platforms, and that an in-the-wild malicious slopsquat package existed before the audit was written. The corrected practitioner position is that controls bind only at four boundaries the code does not own: builder identity and workspace, published-app ingress, the data and connector API, and the agent execution plane. At each boundary the paper gives the exact semantics, the dated vendor defaults, the behavioural test that proves the control works, and the documented bypass. Generation-time controls such as prompts, rules files and AI review measurably shift the correctness-versus-security trade-off but never cap damage; on the one exploit-confirmed benchmark of real deployed vibe-coded apps, **182 of 200 (91.0%)** carried at least one confirmed vulnerability and Broken Access Control appeared in **64.0%** of them ([Deng, Fan and Meng, arXiv 2606.23130v4](#)). The legal layer is technology-neutral and already reaches every failure mode, but GDPR notification is risk-thresholded rather than automatic, a vibe-coded CRUD tool is not an "AI system" under the AI Act, and NIS2 and DORA duties attach only to in-scope entities and, for DORA's strongest clauses, only to critical or important functions. Everything quantitative or evaluative below carries an evidence-confidence tag; the tiered model, the rollout plan and the KPIs marked as proposals are the authors' design, not measured practice.

0. How to read this paper

Date of record. All vendor defaults, prices, regulatory statuses and incident facts are as verified on 8–9 October 2026. Vendor documentation in this market changes monthly; every default below should be re-checked in a trial tenant before procurement.

Evidence-confidence legend. Every quantitative claim and every control verdict carries one of six tags.

Tag	Meaning
[CP] Confirmed-primary	Read directly from the primary source: vendor documentation or changelog, regulation text, EDPB guideline, CVE record, court filing, or the researcher's own write-up.
[VR] Vendor-reported	A vendor's own research, telemetry or evaluation, read at the vendor's page; figures are the vendor's and carry the vendor's sampling and commercial incentives.
[RR] Researcher-reported	Independent academic or researcher work read at source; independent replication is noted where it exists (it rarely does).

Tag	Meaning
[PO] Press-only	Reputable press quoting named parties; the primary source was not located.
[INF] Author-inference	A conclusion the authors draw from cited evidence; reasoning is shown.
[PROP] Proposal	A design, threshold, tier, KPI or rollout step the authors recommend; no external validation claimed.

Structure. Sections 1 and 2 review the original report and the audit. Sections 3 to 11 are the practitioner guidance. The appendix holds machine-readable tables for a presentation build.

Terminology. "Builder" means an AI app builder (Lovable, Replit, Base44, Bolt, v0). "Agent" means a coding agent (Claude Code, Cursor, GitHub Copilot coding agent, Codex, Gemini CLI, Kiro, Antigravity, Devin). "BaaS" means a backend-as-a-service reached directly from the browser (Supabase, Firebase, Neon Data API, Convex, PocketBase, Appwrite). Row-level security is "RLS". Monetary figures are USD list prices as published by vendors, EUR where the law states them; no currency conversion is applied.

1. Review of the original report: what holds, what needed correction

1.1 What holds

The original report's architecture survives intact. Its four failure modes (client-reachable data API with broken authorisation, public-by-default publishing, platform-side bugs, agent destruction with co-located backups) are confirmed by the full incident ledger in section 3, and no incident found in the May–October 2026 extension required a fifth category **[INF]**. Its central claim that controls must be enforced by a layer the generated code does not own is supported by every post-incident vendor remediation, all of which changed defaults or blast radius rather than code correctness: Replit's dev/prod database separation ([Fortune](#)) **[PO]**, Railway's grace period on the API `volumeDelete` mutation ([Railway Central Station](#)) **[CP]**, Supabase's explicit-grants default ([Supabase changelog 45329](#)) **[CP]**, and Lovable's private-by-default projects ([Lovable](#)) **[CP]**.

Statements that fresh primary-source research confirms verbatim or near-verbatim **[CP]**: the Base44 `auth/register` and `auth/verify-otp` mechanism and sub-24-hour fix ([Wiz](#)); Moltbook's four remediation rounds in roughly three hours ([Wiz](#)); the Supabase 30 October 2026 date and the grants-versus-RLS distinction; that Vercel Authentication admits Vercel accounts, not the workforce IdP ([Vercel Authentication](#)); that Cloudflare Access and Google IAP fail open unless the origin validates the proxy's token; every Claude Code sandbox seam it listed, now stated in Anthropic's own documentation ([Claude Code sandboxing](#)); the Lovable DPA's independent-controller carve-out and no-audit-right position ([Lovable DPA](#)); the AI Omnibus dates; the Tea attribution caution ([Simon Willison](#)); and the absence of any DPA enforcement decision on a vite-coded app as of October 2026 **[INF]**.

1.2 What needed correction and why

The report's weakness was evidentiary compression: selected scans, vendor documentation, individual incidents, benchmark results, legal duties and the authors' own design were written at one level of certainty. The table lists the corrections that matter for a reader who will act on the paper; minor wording issues are folded into the relevant sections.

#	Original statement (paraphrased)	Corrected position	Why it matters
1	"The best agent tested produced code that was both correct and secure only 10.5% of the time"	10.5% is SWE-agent + Claude 4 Sonnet, which had the best <i>functional</i> rate (61.0%); the best <i>joint</i> rate was 12.5% (OpenHands + Claude 4 Sonnet); Claude Code with the same model scored 6.0%; range 4.5–12.5% across nine pairings; every run already contained a security reminder (SusVibes Table 3) [RR]	The figure is a joint pass rate for developer agents on CVE-derived Python tasks, not a vulnerability rate for vibe-coded apps
2	"An anonymous visitor can delete your tables"	Default grants were <code>select, insert, update, delete</code> , none of them DDL; a Data API caller can empty a table it has DELETE on but cannot DROP it (Supabase changelog 45329) [CP] ; no incident in the ledger demonstrates DDL via a client key [INF]	Integrity and availability impact is real but is row-level; recovery planning differs
3	Escape found "2,000+ vulnerabilities ... across 5,600 public vibe-coded apps"	5,600 is the web-application count in Escape's asset inventory; 1,400 apps were tested after cleaning ; the PDF says "98 highly critical" while the landing page says "2,038 highly critical" (Escape PDF ; Escape landing) [VR]	Denominator was wrong by a factor of four
4	RedAccess: "about 5,000 held sensitive corporate data" (Axios) vs 40% of 5,000 (WIRED)	The primary PDF defines 5,000 as apps that "appeared to be built for corporate purposes" and 2,000 (40%) as those with sensitive data "deployed without basic security controls"; the 380,000 are assets, not examined apps (RedAccess PDF) [VR]	Axios compressed two populations into one
5	"Benchmark security pass rates ... sat flat at roughly 55% for two years"	True as a population average on Veracode's 80-task, 4-CWE, SAST-judged suite; the same March 2026 report shows GPT-5-series extended-reasoning modes at 70–72% (Veracode Spring 2026) [VR]	"Flat" masks a reasoning-model exception and rests on four injection/crypto CWEs, none of them authorisation
6	"As of July 2026, no in-the-wild [slopsquatting] attack had been reported"	Rested on an uncited Wikipedia sentence; Aikido (20 Feb 2026) and CSA (19 Apr 2026) document <code>unused-imports</code> on npm as a real malicious package on a hallucinated name, ~233 weekly downloads before npm's security hold (Aikido ; CSA) [VR]	Intent is "potential" and no victim compromise is documented, but the categorical negative was false
7	"Exposure triggers the Article 33 72-hour notification"	Notification is due only where a personal data breach exists and is not "unlikely to result in a risk"; individuals are told only at "high risk"; every breach is documented under Art. 33(5) (EDPB Guidelines 9/2022) [CP]	Categorical legal statement replaced by the regulator's decision tree (section 7.1)
8	"Each app processing personal data needs a ROPA entry"	Art. 30 records are per processing activity; an app supports one or more activities; the registry links to activity records and feeds DPIA screening [CP] for the law, [PROP] for the mapping	Source was a vendor blog, not the Regulation
9	AWS logically air-gapped vault includes "multi-party approval for restore"	MPA is an optional integration needing two AWS Organizations, Identity Center and an approval team (AWS MPA) [CP]	Overstated the default posture
10	NCSC's CEO said AI-generated code poses "intolerable risks"	The CEO's RSAC keynote (24 Mar 2026) called for safeguards; the "intolerable risks for many organisations" phrase is from an NCSC blog published the same day (NCSC) [CP]	Misattribution of a quotable line
11	"CVE-2025-59536 allowed RCE through hooks and MCP settings"	Two issues conflated: the hooks RCE was GHSA-ph6w-f82w-28w6 (no CVE, fixed Aug 2025); CVE-2025-59536 was the MCP consent bypass (fixed 1.0.111) (Check Point Research ; NVD) [CP]	Patch-level tracking depends on correct IDs
12	Railway "made API volumeDelete match the dashboard's 48-hour soft delete"; "Railway stores volume-level backups in the same volume"	Railway's wording is a "two-day grace period" / "Delayed delete"; the same-volume claim is PocketOS's account, and Railway also holds separate disaster backups which performed the restore (Railway Central Station ; The Register) [CP]/[PO]	Do not generalise one provider's backup layout
13	AI reviewer "precision ranges from about 20% to 96% depending on who paid"	20–68% is Augment's dataset; 64–96% is the CodeRabbit-commissioned Signal65 dataset; neither reports recall; they cannot be merged (Signal65 ; Liatrio compilation) [VR]	Non-comparable benchmarks presented as one range

#	Original statement (paraphrased)	Corrected position	Why it matters
1 4	"37.6% increase in critical vulnerabilities after five refinement rounds"	The figure appears only in the abstract; the paper body never defines its baseline; cite strategy totals (security-focused 38 vs feature-focused 158 findings) and per-iteration means instead (Shukla et al.) [RR]	Precise-looking number without a denominator
1 5	Netskope: 223 violations/org/month, "54% of them involving regulated data"	54% is the regulated share of <i>personal cloud app</i> violations; for genAI the shares are source code 42%, regulated 32%, IP 16% (Netskope 2026) [VR]	Mis-attached figure
1 6	Retool: "5% of tech leaders very confident ... and 60% of builders building outside IT"	Two different surveys: 307 CTO/CIO/CISOs (Wynter panel, May 2026) and 817 Retool customers/builders (late 2025) (Retool ; Retool) [VR]	Different populations
1 7	"Analysts, the CSA and the few companies that disclose ... all land in the same place: govern, don't block" with Gartner's 60%/30% figures	Gartner's public abstract contains no numbers; 60%/30% are Strategic Planning Assumptions visible only on a vendor reprint (Gartner ; Tray.ai) [CP] ; the CSA note does not address amnesty, kill switches or lifecycle (CSA) [CP] ; Netskope telemetry shows 90% of organisations block some genAI apps while personal-account use fell from 78% to 47% (Netskope 2026) [VR]	Measured practice is "block many, sanction some", not a binary
1 8	Cloudflare's registry records "owner, team, data sources and cost centre"	Owner, team, description, connected data sources and usage metrics; cost attribution is via resource tags, not a cost-centre field (Cloudflare) [CP]	Minor, but the registry schema in section 6.3 is built only from documented fields
1 9	"No named large non-tech enterprise ... has published its approval workflow"	Bounded statement: of about 40 sources reviewed, three organisations (Method, Tenable, EXANTE) describe their practice first-person; none publishes an SLA, registry schema, expiry rule or metric (Method ; Tenable ; Finance Magnates) [CP]	Negative claims need a stated search scope
2 0	PocketOS incident "24 or 25 April"	Friday 24 April 2026; the founder's write-up was published 25 April (The Register) [PO]	Timeline precision
2 1	"ZTNA in front of an app that calls BaaS from the browser: theatre for data"; "BFF structurally stronger"	Replaced by trust-path analysis (section 4.4.3): direct-to-BaaS with verified grants and RLS is a valid enforcement point; a BFF holding a secret key without per-request tenant binding is weaker than that, not stronger (Supabase Edge Functions auth) [CP]/[INF]	Blanket verdicts replaced by conditions
2 2	Wildcard-certificate CT blind spot "my inference and unverified"	Verified by direct TLS probe on 9 Oct 2026 for *.lovable.app, *.replit.app, *.vercel.app, *.netlify.app, *.base44.app (section 4.6) [CP]	Inference promoted to finding
2 3	"Supabase's own guidance now strongly discourages connecting its MCP to production"	The agent-skills blog does say "We strongly discourage" (Supabase blog); the MCP documentation page (dated 8 Oct 2026) uses conditional wording: connect "only when the task requires production evidence", with read-only, project-scoped prerequisites (Supabase MCP docs) [CP]	Both are vendor positions; cite the one you rely on
2 4	Works / theatre table	Replaced by a threat-path efficacy and limitations matrix (section 10) because "works" meant "would have interrupted a chosen incident path", not measured efficacy [INF]	Audit A12

Two items the original omitted entirely and the audit did not raise: the Colorado AI Act was repealed and replaced by SB 189 on 14 May 2026 ([Skadden](#)) **[CP]**, and the CSA's June 2026 note carries an Annex III high-risk date of 2 August 2026 that Regulation (EU) 2026/1744 has since moved to 2 December 2027 ([EUR-Lex OJ L 2026/1744](#)) **[CP]**.

2. Review of the independent audit: confirmed, refined, incomplete

The audit (8 October 2026) was a technical and evidentiary critique that checked a subset of consequential claims against primary sources. Its executive judgment, that the thesis is sound and the certainty labels are not, is correct. Fresh primary-source research confirms all twelve priority corrections, refines eight of them, and finds the audit itself incomplete or out of date in six places.

2.1 Priority corrections A1-A12

ID	Audit finding	Fresh research verdict	What the research adds
A1	Publishable/anon key in the browser is expected design, not a leaked secret	Confirmed	Supabase classifies publishable keys as "Safe to expose online" and says "Anyone can read it, so it only reaches what Row Level Security allows" (Supabase API keys) [CP]; Palmer, Wiz, UpGuard and Reeve each say the key was not the failure; Symbiotic is the outlier that classes it as High [RR]/[VR]
A2	API DELETE removes rows, not tables	Confirmed	Default grants were DML only [CP]; no ledger incident demonstrates DDL [INF]
A3	30 Oct 2026 covers new tables only; existing grants and RLS unchanged; direct connections not covered	Confirmed and refined	Changelog says verbatim "Existing tables are not affected", "RLS behavior remains unchanged", direct connections "will not affect you" [CP]. Refinement: the changelog's revoke SQL covers tables and sequences only; new functions keep PostgreSQL's default EXECUTE TO PUBLIC, so a new RPC in public stays callable by anon after 30 Oct unless the hardening guide's function revokes are also applied (Supabase hardening guide ; Supabase database functions) [CP]/[INF]. The RLS auto-enable event trigger is a separate opt-in object that only postgres can create (Supabase event triggers) [CP]
A4	SusVibes 10.5% is one configuration's joint rate; best joint 12.5%	Confirmed and refined	Claude Code with Claude 4 Sonnet scored 6.0%; a generic security reminder was in every prompt; the released v1.0 dataset has 186 tasks, not 200 (SusVibes ; LeiLiLab/susvibes) [RR]
A5	Art. 33 is risk-thresholded; Art. 34 separate	Confirmed	EDPB 9/2022 paras 17-23, 28-35, 44, 82-83, 121-122 and Annex B supply the decision tree [CP]
A6	Art. 30 is per processing activity	Confirmed	No private-sector source documents a registry-to-ROPA link; GSA's federal plan is the only published chain of use case to dataset registry to privacy assessment (GSA) [CP]
A7	AWS MPA is optional	Confirmed	Two Organizations, Identity Center, RAM-shared approval team, SCP; approval-team resources exist only in us-east-1; no additional MPA charge (AWS MPA) [CP]
A8	Cloudflare AI Gateway DLP skips base64 and cache hits	Confirmed	Audit's own citation stands; streaming blocks may require buffering the full response [CP]
A9	AI Act dates correct; Art. 50 not on every app	Confirmed and refined	Three-question test in section 7.3; Art. 4 now reads "take measures to support the development of AI literacy" with an express no-guarantee clause (AI Act Service Desk , Art. 4) [CP]; Art. 50(2) marking has a grace period to 2 Dec 2026 for generative systems already on the market (Commission FAQ) [CP]

ID	Audit finding	Fresh research verdict	What the research adds
A110	UI-only identity gateways do not secure a separately reachable BaaS API; both paths need independent authz	Confirmed	Trust-path analysis, section 4.4.3 [INF]
A111	BFF is stronger only with least privilege and tenant binding	Confirmed	Supabase's own server-side guidance: the admin client "bypasses Row Level Security, so filter by the caller's ID"; use it "only for work that has to cross those policies" (Supabase Edge Functions auth) [CP]
A112	"Works" was a recommendation mislabelled as proven outcome	Confirmed	Section 10 replaces the table [INF]

2.2 Sections B-J

B (incident evidence). The audit asked for a ledger with incident date, publication date, acknowledgement, layer, capability, impact, remediation, disputed details and source type. Section 3.2 supplies it for 12 core and 8 new incidents. Every audit judgment in section B is upheld, and three "open" items are now resolvable: the CVSS gap is a Scope-metric difference (researcher S:U 8.26 vs MITRE S:C 9.3) ([Palmer](#); [MITRE CVE JSON](#)) **[CP]**; the Escape denominator is 1,400 **[VR]**; the RedAccess 5,000/2,000 is reconciled from the PDF **[VR]**. The Lovable regression scope remains contested, but Lovable's own concession that free-tier projects were public by default until November 2025 narrows the gap for free-tier users ([Lovable](#)) **[CP]**.

C (statistics). All seven items executed in section 5. On C7 (slopsquatting) the audit's direction was right, but it treated the question as "absence of evidence is weak evidence of absence" when a positive case existed seven weeks before the audit date **[VR]**.

D (vendor capability). The four-boundary model is adopted as the organising principle of section 4. The eight-column buyer-validation matrix was built and dated (section 4.2).

E (agent controls). The audit's warning that "deterministic" must not mean "cannot be bypassed" is confirmed in the vendors' own words: Anthropic says Bash deny rules are not "a security boundary around the program" ([Claude Code permissions](#)); GitHub says the Copilot firewall "should not be considered a comprehensive security solution" ([GitHub Docs](#)); Cursor says Auto-review is "not a security boundary" ([Cursor Run modes](#)) **[CP]**.

F, G, H, I, J. Adopted. F is extended with the controller/processor analysis for personal sign-ups (7.1) and the DORA Art. 30(3)(e) audit-rights gap (7.8); G's "Discovery" discussion item is now a verified finding; H's seven invariants and I's ten tests are carried into section 9 with database-level assertions (SQLSTATE and row counts) and RPC/Storage surfaces; every P0, P1 and P2 rewrite item in J is executed in this paper.

2.3 Where the audit was incomplete or wrong

1. **A3 omitted RPC.** The audit listed "security-definer functions, public views and unsafe RPC endpoints" as needing independent inspection but did not state that the 30 October change

leaves function `EXECUTE` defaults untouched, which is the specific reason an agent-created RPC can remain anonymously callable in a project that believes itself "secure by default" **[CP]/[INF]**. It also did not note that the RLS event trigger is opt-in per project, nor that the default-privilege revokes are issued `for role postgres` and would not cover tables created by another owner role **[INF]**.

2. **Wildcard certificates.** Listed as a discussion topic (G, "Discovery"); now empirically verified for all five platforms, with the consequence that EASM attribution by certificate name or netblock cannot work for platform subdomains (section 4.6) **[CP]**.
3. **Slopsquatting.** The `unused-imports` case (Aikido, 20 Feb 2026) predates the audit; the audit's C7 should have said "one confirmed malicious package, intent probable, impact unquantified" **[VR]**.
4. **NCSC attribution.** Not caught **[CP]**.
5. **Colorado.** The audit's US coverage was limited to CCPA; the Colorado AI Act's repeal and replacement (14 May 2026) was five months old at audit date **[CP]**.
6. **CSA's superseded date.** The audit cited the CSA note without flagging that its 2 August 2026 high-risk date had been overtaken by Regulation 2026/1744 on 27 July 2026 **[CP]**.
7. **Smaller misses.** The CVE-2025-59536 conflation, the Railway "48-hour" paraphrase, the Netskope 54% mis-attachment, the Retool two-survey conflation and the Gartner-forecast-via-reprint provenance were not raised **[CP]/[VR]**.

None of these reverses an audit conclusion; they are gaps in a review that was explicit about not being line-by-line. The audit's instruction to obtain qualified legal review before publication stands and is repeated in section 11.

3. Four failure modes and the verified incident ledger

3.1 The four failure modes, restated precisely

Failure mode 1 — broken authorisation on an internet-reachable data API. The browser holds an intentionally public key and talks to PostgREST, Firebase or an equivalent. Exposure is decided by grants (may this role touch the table at all), RLS (which rows), column privileges, view and function ownership, and the logic of each policy. The key is not the defect; in every incident of this class the primary source says so **[CP]**. The characteristic defects are: no RLS; RLS with a permissive `USING (true)` policy; `T0 authenticated` with no tenant predicate (authentication without authorisation); inverted logic (the EdTech RPC that "blocks the people it should allow and allows the people it should block" ([The Register](#)) **[PO]**); and `SECURITY DEFINER` functions or owner-privileged views that bypass RLS silently ([Supabase RLS docs](#)) **[CP]**.

Failure mode 2 — public-by-default publishing. Not a code defect. The platform publishes to the open internet unless the builder changes a setting; the app is indexed; nobody in the organisation knows it exists. The RedAccess sweep is the canonical case and the vendors' reply ("a public app is not a breach") is technically correct and is the point ([Axios](#)) **[PO]**.

Failure mode 3 — platform-side authorisation bugs. Base44's unauthenticated registration endpoints and Lovable's February–April 2026 ownership-check regression share one root cause, authentication without object-level authorisation, and no app-level control could have helped **[CP]/[INF]**. Chat histories, prompts and source trees are data stores held by the platform.

Failure mode 4 — agent credential reach. An agent holding a credential that can mutate production, delete a volume or run `terraform destroy` does so, usually after a context mismatch, sometimes against explicit instructions. The constant across Replit, Cursor/Claude, Claude Code,

Kiro and Antigravity incidents is credential reach, not model vendor **[INF]**. Where backups live in the same identity domain as the credential, they go too.

3.2 Master incident ledger

Confidence: **High** = first-party or primary researcher source read directly; **Medium** = reputable press quoting a named party, primary not located; **Low** = secondary or single-user forum report. Capability codes: R read rows, W insert, U update, D delete rows (not DDL), ACCT unauthorised account creation, SRC source/secret exposure, VOL volume or instance deletion, CRED credential theft.

#	Incident	Incident date	Layer	Capability	Confirmed impact	Remediation	Disputed	Source / confidence
1	Lovable RLS, CVE-2025-48757	Discovered 20 Mar 2025; write PoC 24 May 2025	App authz (generated RLS)	R, W, SRC	303 endpoints across 170 of 1,645 showcase projects (10.3%), homepage-only lower bound; inserted <code>payment_status: paid</code> bypassing Stripe	None by vendor ("Fixed Versions: None"); Lovable 2.0 scanner checks RLS presence	CVSS 8.26 (S:U) vs 9.3 (S:C); MITRE tags "disputed"	Palmer; MITRE; High
2	Tea app Firebase	25 Jul 2025; second exposure 28 Jul	Legacy storage ACL	R	~72,000 images (~13,000 ID selfies); >1.1M DMs	System migration; identity protection	AI attribution: Willison "confident vibe coding was not to blame"; data pre-Feb 2024	Willison; E.D. La. complaint; High on facts
3	Base44 auth bypass	Jul 2025; fixed <24h	Builder platform	ACCT	Verified accounts on SSO-only private apps; Wix: no evidence of abuse	Fixed <24h	Exact dates not published	Wiz; High
4	Replit agent / SaaS	18 Jul 2025	Agent plane	D, W	">1,200 executives, >1,190 companies" (Lemkin's figures); 4,000 fabricated records; data recovered via rollback the agent said was impossible	Dev/prod DB separation; planning mode	Counts not re-audited	Fortune; The Register; Medium
5	Moltbok Supabase	31 Jan-1 Feb 2026	App authz (no RLS)	R, U	~4.75M records; 1.5M agent API tokens; 35,000 emails; 4,060 DMs with plaintext OpenAI keys	Four fixes in 3h12m; write survived fixes 1-2	Key was <code>sb_publishable_</code> , not <code>service_role</code>	Wiz; High
6	Lovable-showcased EdTech app	Feb 2026	App authz (inverted RPC)	R, U, D, W	18,697 user records; 4,538 student accounts; 870 full PII	Owner fixing; Lovable: "at the discretion of the user"	Researcher write-up not located	The Register; Medium
7	Symbiotic scan	pub. 2 Jun 2026	App authz at scale	R, U, D, W	1,072 scanned; 1,046 (98%) ≥1 finding; 173 (16%) critical; 172 unauthenticated DELETE; 39 fully readable	Names withheld	Classes anon key in JS as High	Symbiotic; High for own numbers
8	Escape scan	pub. 29 Oct 2025	App authz at scale	R, state-altering	1,400 apps tested; 34,232 findings; 400+ secrets; 175 PII instances incl. IBAN and plaintext password	Not stated	5,600 vs 1,400; 98 vs 2,038 "highly critical"	Escape PDF; High for own numbers
9	Lovable regression / BOLA	3 Feb-20 Apr 2026	Builder platform	SRC, R chat	Lovable: public-project chat and source reachable by any user with a link; researcher: every pre-Nov-2025 project incl. <code>SUPABASE_SERVICE_ROLE_KEY</code>	Fix within two hours of 20 Apr; all public projects made private; HackerOne triage restructured	Scope; service_role exposure unconfirmed by Lovable	Lovable; TNW; High on existence, contested on scope

#	Incident	Incident date	Layer	Capability	Confirmed impact	Remediation	Disputed	Source / confidence
10	Pocket OS / Railway / Cursor	Fri 24 Apr 2026	Agent plane + infra API	VOL	Production volume and volume-level backups deleted in ~9 s via over-scoped CLI token found in an unrelated file; restored from Railway disaster backups	API volumeDelete given two-day grace period	Model attribution; forensic detail	The Register ; Railway Central Station ; High on mechanism
11	RedAccess sweep	pub. 7 May 2026	Organisational defaults	R via public URL	380K+ assets; 5,000 corporate-purpose; 2,000 (40%) sensitive without controls; Axios and WIRED verified several	Some apps taken private	URLs withheld from vendors; Wix: two examples deliberately public	RedAccess PDF ; Axios ; High on PDF figures
12	UpGuard Supabase sweep	pub. 24-25 Sep 2026	App authz + grants at scale	R	16,326 databases with readable tables from ~300,000 domains; >50% PII indicators; 65,467 users with passport/PAN data; 25,000 consulate records in France; 884 plaintext passwords	Owners notified	TechCrunch "about 16,000 with personal data" compresses ">half"	UpGuard ; TechCrunch ; High

Incidents and scans surfaced after the original report (March-October 2026):

#	Incident	Date	Layer	Capability	Impact	Remediation	Source / confidence
13	DataTalks.Club, Claude Code terraform destroy	11 Mar 2026	Agent plane	VOL	~2M rows of student data; AWS restored within 24 h	n/a	Lyrie (secondary) ; Low-Medium
14	Pillar: Gemini CLI GitHub-issue injection to GCP Editor	Reported 11 Jun, fixed 14 Aug 2026	Agent plane (CI)	CRED	RCE on runner, WIF credential file exfiltrated, project-wide serviceAccountTokenCreator over-grant	.geminii ignore ; role scoped; tool scoping	Pillar Security ; High
15	Reeve "State of Vibe-Coded App Security 2026"	Scan 12-14 Aug 2026	App authz at scale	R (never reads a row)	30,998 apps; 3,680 checkable; 2,096 (57%) ≥1 readable table; 1,332 shipped a secret	n/a	Reeve ; High for own numbers
16	Claude Code issue #88753, TRUNCATE on live RDS	22 Aug 2026	Agent plane	D	Shared staging RDS tables truncated after context compaction dropped the correct DSN	Open	GitHub issue ; Medium
17	Vibe App Scanner report	Dec 2025-Aug 2026	App authz	R/W	1,215 scans; 39.3% of 359 Supabase apps flagged; self-selected sample	n/a	Vibe App Scanner ; Medium
18	Antigravity forum reports	20 and 26 Sep 2026	Agent plane	git push to prod main; 14-min rmdir /s /q	Single-user reports; Google staff "deeply concerning"	Advice only	Google AI forum ; Low

#	Incident	Date	Layer	Capability	Impact	Remediation	Source / confidence
19	AWS Cost Explorer outage attributed to Kiro	Dec 2025; reported 20 Feb 2026	Agent plane	"delete and recreate the environment"	13-hour interruption; Amazon: "misconfigured access controls, not AI"	Mandatory peer review for production access	Reuters ; Amazon ; Disputed
20	Sentry MCP "agentjacking" (Tenet Security)	Disclosed 3 Jun 2026	Agent plane (MCP)	CRED	PoC: injected error events read via Sentry MCP exfiltrated env vars, cloud and CI secrets; "85% exploitation success"; 2,388 organisations with injectable DSNs; Sentry declined root-cause fix	Content filter	CSA ; High (PoC, not in-the-wild)

The agent-plane record also includes two researcher-disclosed CI cases: [claude-code-action](#) CVE-2025-66032 (bot-name trust bypass, fixed within four days, disclosed 1 Jun 2026) and "Clinejection", which the CSA describes as exploited in the wild ([CSA](#)) **[CP]** for the CVE, **[PO]** for the in-the-wild claim. Pillar's "Week of Sandbox Escapes" produced Cursor CVE-2026-48124 (fixed 3.0.0) and a Codex fix in v0.95.0 ([cybernoz](#), [secondary](#)) **[PO]**.

3.3 Reconciled figures

RedAccess. The PDF is unambiguous: "380K+ publicly accessible web assets" across Lovable, Replit and Base44; "5,000 appeared to be built for corporate purposes"; "2,000 of those (40%) contained sensitive corporate, operational, or personal data deployed without basic security controls" ([RedAccess PDF](#)) **[VR]**. Axios's "about 5,000 containing sensitive corporate data" and WIRED's "5,000 ... virtually no security or authentication" each compress one step; TechTarget matches the PDF. The enumeration method is undisclosed; Wix said two examples it was shown had been "deliberately set to public" ([Axios](#)) **[PO]**. Treat the 2,000 as a credible, partly press-verified signal with an undisclosed denominator **[INF]**.

Escape. 14,600 assets, of which 5,600 web applications; "1.4K applications tested after cleaning"; 34,232 findings; the PDF's "98 highly critical" and the landing page's "2,038 highly critical" cannot both be right under one definition ([Escape PDF](#); [Escape landing](#)) **[VR]**. Health and education domains were excluded and the sample is roughly 4,000 Lovable launch-directory apps plus small Base44 and Create.xyz sets ([Escape methodology](#)) **[VR]**.

Lovable regression. Lovable: "Between February 3, 2026 and April 20, 2026 public project chat history and source code could potentially be accessed by any Lovable user provided they had a project link"; private projects and Lovable Cloud "never impacted"; first HackerOne report 22 February, "closed without being escalated"; "Our first public response was dismissive" ([Lovable](#)) **[CP]**. Researcher: `/projects/{id}/*`, `/git/files`, `/git/file`, `/documents` returned 200 for pre-November-2025 projects; source contained `SUPABASE_SERVICE_ROLE_KEY`; "Firebase auth tokens are checked, but ownership is never verified" ([LinkedIn relay of @weezerOSINT](#)) **[RR]**. Lovable has not confirmed or denied the service-role exposure; the number of projects actually viewed by non-owners was "in progress" as of 22 April. One affected project was a Danish nonprofit's member database ([TNW](#)) **[PO]**.

UpGuard. "16,326 databases exposing readable tables"; "Over half of the databases had indicators of some PII"; UpGuard's mechanism statement, "Tables created programmatically through the API, which is how coding agents interact with Supabase, do not enable RLS by default", is the clearest vendor-independent account of why builder-provisioned projects leak

(UpGuard) [VR]. BleepingComputer's caveat applies: the scan does not establish that every site was AI-built (BleepingComputer) [PO]. Both UpGuard and Cybernews misname the CVE-2025-48757 researcher as "Matt Turner" (correct: Matt Palmer) [CP].

CVSS. Palmer's vector AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N scores 8.26; MITRE's record carries S:C, scoring 9.3; everything else is identical (Palmer; MITRE) [CP]. CISA's ADP enrichment rates Exploitation "poc", Automatable "yes" [CP].

3.4 The scans are not independent samples

Escape, Symbiotic, Reeve, Vibe App Scanner and UpGuard all over-sample Lovable launch directories, search dorking and certificate transparency; Reeve's 57% is effectively a Lovable-to-Supabase figure because 3,553 of its 3,680 checkable apps were Lovable (Reeve) [VR]. Symbiotic's 39 "fully readable" of 1,072 and Reeve's 2,096 "at least one readable table" of 3,680 use different definitions and cannot be reconciled from what they publish (Aliteq) [PO]. The one roughly comparable pair across 17 months is Palmer's 10.3% of showcase apps (March 2025) against roughly 10.9% of 18,554 Lovable apps readable in Reeve's August 2026 sweep (host0 arithmetic) [PO]; methods differ, so this is absence of visible improvement, not evidence of stasis [INF]. The only randomly sampled population study is Deng, Fan and Meng's 200 deployed apps (section 5.9) [RR].

3.5 Layer attribution and the single interrupting control

Incident	Layer	Primary wording supporting attribution	Interrupting control (inference)
CVE-2025-48757, Moltbook	App authz	"The core issue was not an exposed public API key ... but the absent RLS configuration" (Palmer); "this critical line of defense was missing" (Wiz)	Behavioural anon-role test as publish gate; no default grants to anon
EdTech app	App authz (logic inversion)	"The guard blocks the people it should allow and allows the people it should block" (The Register)	Cross-role behavioural test, not presence check
Symbiotic, Escape, Reeve, UpGuard	App authz at scale	"Tables created programmatically ... do not enable RLS by default" (UpGuard)	Explicit-grants default closes the new-table path only; existing tables need audit
Base44	Platform auth	Registration endpoints "exposed without authentication" (Wiz)	Vendor-side only
Lovable BOLA	Platform authz	"ownership is never verified"; "backend regressions re-enabled public access" (Lovable)	Vendor object-level authz tests; customer: private projects, no secrets in chat
Replit/SaaStr	Agent credentials	"Replit agent in development deleted data from the production database" (Fortune)	Platform-enforced dev/prod separation (the fix shipped)
PocketOS	Agent credentials + infra API	Token "scoped for any operation"; legacy endpoint lacked "Delayed delete" (The Register)	Any one of: scoped token; token outside agent-readable filesystem; API soft-delete; off-volume backups
Gemini CLI (Pillar)	Agent plane (CI)	- -yo!o with inert allowlist; WIF file on runner; project-wide token-creator role (Pillar)	Least-privilege WIF role; no untrusted input to a credentialed agent
Kiro/AWS	Agent credentials	Kiro "had the permissions of its operator" (The Verge)	Peer-reviewed production access (the fix)
RedAccess	Organisational defaults	Settings "set to make the apps publicly accessible unless users manually changed them" (Axios)	Tenant-level private/SSO default; outside-in discovery

Vendor remediation after every incident targeted defaults and blast radius (private-by-default, dev/prod split, soft delete, explicit grants), never the correctness of customer authorisation logic [INF]. Regulatory consequences to date: the Tea class action reached a settlement in principle

on 30 June 2026 ([Settlement Insight, secondary](#)) **[PO]**; no DPA decision on any ledger incident was found; the UK ICO opened a six-week call for evidence on agentic AI on 8 October 2026, stating "the fact AI agents act with autonomy is not an excuse for poor compliance" ([ICO](#)) **[CP]**. EU exposure is documented in at least five incidents: Lovable is Stockholm-based, the April 2026 BOLA exposed a Danish nonprofit, RedAccess verified UK clinical-trial and customer-service exposures, Escape found IBANs, and UpGuard found a consulate database in France **[CP]/[PO]**.

4. Four security boundaries and the controls at each

4.1 The boundary model

A vibe-coded deployment crosses four independent trust boundaries. Conflating them produces both false assurance (an identity-aware proxy on the UI that leaves the data API open) and false alarm (a publishable key in a bundle treated as a leaked secret). Each boundary has its own question, its own enforcement locus and its own test.

Boundary	Core question	Enforcement locus	Correct test
B1 Builder identity and workspace	Who may create projects, connect data sources, publish externally, download code?	Builder tenant admin policy; IdP via SSO/SCIM	Attempt each action as a non-admin member; attempt from a personal account; export the inventory
B2 Published-app ingress	Who can load the app and call its server routes, through every origin?	Platform deployment protection, identity-aware proxy, app-level auth	Anonymous requests to canonical domain, platform subdomain, preview URLs, bypass headers
B3 Data and connector API	What may a principal read or change, through every surface?	Database grants, RLS, column privileges, function and view ownership; BFF authorisation; connector scopes	Anonymous, same-tenant and cross-tenant requests against REST, GraphQL, RPC and Storage, asserting on rows returned and SQLSTATE
B4 Agent execution plane	What can the coding agent read, install, transmit or destroy?	OS sandbox, egress proxy, credential scope and placement, MCP tool allowlists, dev/prod separation, backup isolation	Search the agent's reachable filesystem, environment and tools for production credentials; attempt a destructive call; restore from an isolated copy

The audit's observation holds: a Cloudflare Access-protected HTML page with a separately reachable Supabase API is two boundaries, and "the public API is not automatically insecure if it enforces properly designed grants and RLS", while "a BFF that proxies through an unrestricted service-role credential is not automatically safe" **[INF]**.

4.2 Boundary B1: builder identity and workspace

4.2.1 Dated buyer-validation matrix

Every row was re-checked against vendor documentation on 8–9 October 2026; "verified on" is the vendor page's own last-updated stamp where one exists. Only three products ship an admin-enforced, inherited "no public apps" policy with no per-builder override: Replit ("Private deployments: Require"), Base44 ("Apps SSO") and Microsoft Power Platform (Entra by construction). Vercel and Netlify have team defaults that are overridable per project. Lovable's default for first publish remains "Anyone" **[CP]**.

Vendor (verified)	Default exposure of a new production app	Admin can force private/SSO for all new apps?	SKU for the enforcing control	Known bypasses
Lovable (undated docs, fetched 8 Oct 2026)	"Default website access" = Anyone (options Anyone / Workspace) (Lovable privacy settings)	Partially: default can be set to "Workspace" and "Who can publish externally" restricted to Admins/Owners; per-project override of the default remains in the publish flow	Website access: Business/Enterprise; external-publish restriction: Enterprise	Per-project override; preview links enabled by default; code downloads enabled by default; "Block publishing with critical issues" and "with PII" disabled by default except in new Enterprise workspaces
Replit (undated, fetched 8 Oct 2026)	Personal workspace Public ; organisation workspace defaults to a private option (Replit)	Yes: "Private deployments" = Off / Require / Require for non-admins; applies to newly published apps only (Replit)	Enterprise privacy settings; "Require Private Deployments" listed for Pro and Enterprise	Does not retro-apply to already-published apps; External access tokens (8 May 2026) reach private deployments; password option is a shared secret
Base44 / Wix (undated, fetched 8 Oct 2026)	Per-role "Default visibility"; four levels Private / Workspace / Public (login) / Public (no login); embedding policy "starts at Anyone" (Base44)	Yes: "Apps SSO" toggle makes all apps use workspace SSO, locks app-level settings, "public apps now require sign-in"; role rules can block publishing with "Request to publish"	Business or Enterprise; data in/out policy Enterprise (page inconsistent)	Embedding default Anyone; per-app override of auto-admit; auth tokens in localStorage, HttpOnly cookies "aren't currently available" (Base44 security)
Bolt (fetched 8 Oct 2026)	Not documented on public pages	Not documented	Enterprise page: SSO (Okta, Azure AD, SAML), provisioning, domain restriction, BYOK deployment (Bolt Enterprise)	Unknown: visibility defaults, publish approval, audit and inventory not found (gap)
v0 / Vercel (docs 15-16 Sep 2026)	Standard Protection: all deployments except production protected; *.vercel.app URLs "are public and can be indexed" (Vercel ; Vercel KB)	Team default for new projects (level + method), "You can override this default on individual projects"; team-wide defaults since 13 Jan 2026	Vercel Authentication on All Deployments free on all plans since 9 Sep 2026 but opt-in; Passport (own IdP) and Trusted IPs Enterprise; Password USD 20/project/month on Pro (Vercel changelog)	Shareable Links; automation bypass header; Protection Exceptions; disabling then re-enabling keeps old cookies valid; Owners can view teammates' v0 chats by URL (v0 Enterprise)
Netlify (docs 7 Oct 2026)	Public ; Free/Personal credit plans have no password protection (Netlify)	Team Owners set default password-protection scope and type for new sites; "Site-level settings override team defaults"	Team login + "Only SSO allowed (strict)": Enterprise; basic password: Pro	Site-level override; every visitor passing team login "needs a paid Netlify seat" (Netlify KB)
Cloudflare (reference architecture 28 Sep 2026)	Not a product: apps reached only through a dispatch worker behind Access (Cloudflare)	Yes by construction	Zero Trust free to 50 users, USD 7/user/month pay-as-you-go (plan page excerpt; confirm)	Build-it-yourself on Workers for Platforms; no documented prevention of a generated app embedding an external BaaS key other than egress allowlist
Microsoft Power Platform (Jun-Sep 2026)	Entra-authenticated; sharing to users/groups; code-app compiled assets served from "a publicly accessible endpoint that doesn't support IP-based restrictions today" (Code apps)	Yes: Conditional Access per app, sharing limits, DLP, App Quarantine, Inventory Block (Manage apps)	Managed Environments entitlement with standalone licences; not in Developer Plan	Environment routing "is not a hard lock"; default environment still needs DLP and sharing limits

Vendor (verified)	Default exposure of a new production app	Admin can force private/SSO for all new apps?	SKU for the enforcing control	Known bypasses
Retool (fetched 8 Oct 2026)	Org members via groups (Use/Edit/Own); "External apps" publish outside the org (Retool)	Group-based additive permissions; Business adds custom groups; Enterprise adds SAML/OIDC	Business (custom groups, audit logs), Enterprise (SSO, SIEM)	Whether admins can globally disable external apps not confirmed (gap)
Superblocks (fetched 8 Oct 2026)	Behind Superblocks SSO/RBAC; "Every database query and API call is centrally audited" (Superblocks docs)	IT configures integrations, SSO, RBAC once; "Every app inherits those guardrails"	Not published	Public-app controls not documented (gap)
Service Now App Engine (10 Sep 2026)	Scoped apps inheriting ACLs; promotion via AEMC checkpoints (ServiceNow)	Yes: AEMC approvals; Build Agent generates ACLs and requires admin role	App Engine (pricing not published)	n/a on pages fetched

A freshly provisioned Lovable Business workspace publishes publicly unless an admin changes two settings on day one; Enterprise workspaces created by Lovable start with scan-based publish blocks enabled but not with "Workspace" website access **[CP]/[INF]**.

4.2.2 Which identity each "SSO" gates

"SSO" on a pricing page almost always means builder-console login. The buyer must ask two questions separately: can my IdP be the only way into the console, and can my IdP be the only way into every published app, enforced by an admin with no per-app override?

Vendor	What "SSO" gates	End-user identity for the deployed app	Source
Lovable	Console (OIDC/SAML Business+; SCIM Enterprise)	"Workspace" access = Lovable workspace members; app-level login methods can be restricted to SAML SSO or workspace identity but forcing a single method for all apps is not explicit	Lovable for Enterprise
Replit	Console (SSO/SAML + SCIM, Enterprise)	Private apps require a Replit login by an organisation member; Viewer seats for non-builders	Replit Private Deployments
Base44	Workspace SSO for builders; Apps SSO forces all apps through workspace IdP	Workforce IdP when the toggle is on	Base44
Vercel	Team SAML for console; Vercel Authentication admits Vercel accounts (team/project/access-group members, Shareable Link holders, bypass header)	Passport (Enterprise) gates visitors through the customer's OAuth 2.0/OIDC IdP; SAML and Entra not named	Vercel Authentication; Passport
Netlify	Team SSO = "dashboard access"; team login admits Owners/Developers/Billing Admins with paid seats	No workforce-wide gate without seats; app-level login is separate	Netlify KB
Cloudflare Access	IdP on every request to the hostname	Workforce or third-party identities per policy; origin must validate	Cloudflare
Power Platform	Entra for makers and end users; Conditional Access per app	Entra ID	Manage apps

Only Base44 answers yes to both questions in its documentation; Lovable answers yes to the first and "restrictable but not forced" to the second; Vercel answers yes to both only on Enterprise via a Passport team default that remains project-overridable **[INF]**.

4.2.3 Inventory exports with owner and data-source metadata

Three platforms document a downloadable tenant-wide inventory with owner and data-source metadata. Lovable Security insights (Business/Enterprise) lists owner, publish status, security and PII findings, auth providers, external access, **connectors**, Lovable Cloud status and secret names, with "Externally published", "no owner" and "abandoned" filters and CSV export up to 100,000 rows ([Lovable Security insights](#)) **[CP]**. Power Platform's inventory covers agents, apps (including code and vibe apps), flows, connectors (preview) and environments via CSV, API, `pac resource-query` and Azure Resource Graph, with connector-usage mapping (preview), orphaned-owner detection and in-place Block ([Power Platform inventory](#)) **[CP]**. ServiceNow's AI Control Tower shows "what data they access" ([ServiceNow](#)) **[CP]**. Replit offers a Security Center with SBOM download and SIEM-streamed audit logs but no documented export with data-source fields ([Replit Enterprise](#)); Vercel and Netlify expose project lists and protection settings only **[CP]**. Lovable's audit log is retained about 13 weeks on Enterprise; tamper-evidence is not stated ([Lovable for Enterprise](#)) **[CP]**.

4.3 Boundary B2: published-app ingress

4.3.1 Identity-aware proxies and origin validation

All four mainstream IAPs depend on the origin being unreachable except through the proxy, or on the origin validating a signed assertion. Cloudflare: "To secure your origin, you must validate the application token issued by Cloudflare Access"; publicly routable origins must protect the origin IP by other means ([Cloudflare](#)) **[CP]**. Google IAP: apps must "use signed headers"; on Compute Engine or GKE anyone reaching the serving port bypasses IAP; on Cloud Run the auto-assigned `run.app` URL "might be directly accessible" unless disabled or ingress-restricted ([Google IAP](#)) **[CP]**. Entra Application Proxy: "Passthrough preauthentication doesn't trigger Microsoft Entra authentication, so Conditional Access Policies can't be enforced"; P1/P2 licence required ([Entra app proxy FAQ](#)) **[CP]**. Zscaler ZPA App Connectors "do not accept inbound connections" ([Zscaler](#)) **[CP]**.

For apps on Vercel, Netlify or Lovable platform subdomains, an IAP in front of a custom domain protects only that hostname; the platform subdomain and any direct BaaS endpoint remain reachable unless separately locked. Vercel's own docs say `*.vercel.app` URLs stay public unless Deployment Protection covers "All Deployments" ([Vercel KB](#)) **[CP]**. The requirement is therefore three-part: IAP on the custom domain with origin validation, platform-level protection on the platform subdomain and previews, and boundary B3 controls on the data path **[INF]**.

4.3.2 Password protection and shared links

Password protection is a shared secret with no per-user revocation; on Vercel Pro it costs USD 20 per protected project per month and is included on Enterprise ([Vercel Deployment Protection](#)) **[CP]**. Replit documents it as "different from private access tied to an authenticated identity" ([Replit](#)) **[CP]**. Vercel Shareable Links and the automation bypass header are documented bypasses of Vercel Authentication **[CP]**.

4.3.3 Tailscale Funnel is an anti-pattern

Funnel exposes a local service to the public internet; "Anyone with the Funnel URL can reach the shared resource", no visitor sign-in is described, and "Enabling Funnel through the CLI adds a default that lets all autogroup:member users use it" ([Tailscale Funnel](#)) **[CP]**. Serve is the tailnet-only equivalent.

4.4 Boundary B3: the data and connector API

4.4.1 Supabase semantics: schema exposure, grants, RLS, columns, views, RPC

Four independent PostgreSQL mechanisms gate a Supabase Data API request, in this order. First, schema exposure: with the Data API disabled "none of the auto-generated REST endpoints respond, regardless of grants or RLS" ([Supabase hardening guide](#)) [CP]. Second, table and column grants: "Grants decide whether a role can run an operation on the table at all"; "A missing grant raises a 42501 error before any policy runs"; and "Adding policies doesn't take those grants back" ([Supabase RLS docs](#)) [CP]. PostgREST's model is that "All authorization happens in the database"; requests with no JWT run as the anonymous role, and a JWT role claim causes `SET LOCAL ROLE` for the request ([PostgREST auth](#)) [CP]. Third, RLS: when enabled, "If no policy exists for the table, a default-deny policy is used"; permissive policies combine with `OR`, restrictive with `AND`; superusers, `BYPASSRLS` roles and table owners bypass it; referential-integrity checks "always bypass row security" and can be a covert channel ([PostgreSQL ddl-rowsecurity](#)) [CP]. An `UPDATE` policy needs a corresponding `SELECT` policy, and without `WITH CHECK` "the using expression decides both which rows are visible and which new rows are allowed", so a user can reassign a row's `user_id` to another user ([Supabase RLS docs](#); [Supabase SKILL.md](#)) [CP]. Authorisation claims must come from `app_metadata` (`raw_app_meta_data`), never `user_metadata`, which "can be modified by authenticated end users" [CP]. Fourth, column privileges, which work "independently from RLS" but break `select *` for restricted roles and are labelled "an advanced feature" ([Supabase column-level security](#)) [CP].

Two side paths bypass all of the above unless configured. Views "bypass RLS by default because they are usually created with the `postgres` user"; on Postgres 15+ `security_invoker = true` makes a view obey the invoking user's policies ([Supabase RLS docs](#); [PostgreSQL CREATE VIEW](#)) [CP]. Functions: "By default, any role can run a database function", including `anon`; a security definer function owned by `postgres` has `bypassrls` and "can return rows the caller isn't allowed to read"; without a pinned `search_path` a caller can hijack an unqualified name ([Supabase database functions](#)) [CP]. The agent skill's rule is blunt: "Never add `SECURITY DEFINER` to resolve a permission error; it silently removes access control" [CP]. Security Advisor lints exist for each (0010 security definer view, 0028/0029 security definer functions executable by `anon`/authenticated, 0011 mutable search path, 0024 permissive policy, 0025 public bucket allows listing) ([Supabase database advisors](#)) [CP], but lints 0008 and 0024 are presence and pattern checks; they cannot tell whether a predicate matches the tenancy model [INF]. The GraphQL path (`pg_graphql`) follows the same grants and RLS; introspection is off by default from 1.6.0; `pg_graphql` stopped being enabled by default on new projects on 18 May 2026 ([Supabase GraphQL](#); [changelog 45329](#)) [CP].

4.4.2 What the 30 October 2026 change does and does not do

Changelog 45329 (published 28 April 2026) is precise [CP]. New tables in `public` no longer receive the default `select`, `insert`, `update`, `delete` grants to `anon`, `authenticated` and `service_role`; without an explicit `GRANT`, PostgREST returns 42501 with the hint "GRANT SELECT ON public.your_table TO anon;". Dates: new default for all new projects 30 May 2026 ("gradual rollout over a few weeks"); applied to all existing projects **30 October 2026**. Verbatim limits: "Existing tables are not affected in your project, they keep their current grants and stay reachable"; "RLS behavior remains unchanged"; direct connections "will not affect you"; `storage`, `auth`, `realtime`, custom schemas and self-hosted deployments are out of scope ([Supabase changelog 45329](#)).

Three consequences the audit did not draw **[INF]**. The changelog's early-adoption SQL revokes default privileges on tables and sequences only; the hardening guide separately revokes `EXECUTE` on functions from `anon`, `authenticated`, `service_role` and `public` ([Supabase hardening guide](#)) **[CP]**. A new RPC function in `public` therefore stays callable by `anon` after 30 October unless the project also applies the function revokes; RPC exposure is a separate audit item. The RLS auto-enable event trigger (`ensure_rls` on `ddl_command_end`) is a per-database object only `postgres` can create, covers only `public`, enables RLS but adds no grants or policies, and "Existing tables still need RLS enabled manually" ([Supabase event triggers](#)) **[CP]**; its presence on a builder-provisioned project must be verified with `select evtname from pg_event_trigger`, not assumed. And the default-privilege statements are issued for role `postgres`; PostgreSQL default privileges are per creating role, so tables created by a different owner role would not be covered (PostgreSQL semantics; not discussed by Supabase). Whether the 30 October rollout for existing projects is instantaneous or gradual like the May rollout is not stated; test after the date **[INF]**.

"Secure by default" after 30 October therefore means only that a new table the agent forgets to grant is unreachable via REST and GraphQL. A table the agent does grant to `anon` with no RLS, or with a `USING (true)` policy, is as exposed as before. Grants are necessary, not sufficient; RLS is necessary, not sufficient; both plus correct policy logic are required **[INF]**. The practical privileged paths to audit on any project are: anything using a `secret` or `service_role` key; `security definer` functions and views in exposed schemas; custom roles with `bypassrls`; direct Postgres connection strings held by apps or agents **[INF]**.

Key model: publishable keys (`sb_publishable_`) are designed to be `public` and map to `anon` or `authenticated`; secret keys (`sb_secret_`) map to `service_role`, bypass RLS and are rejected with HTTP 401 when sent from a browser; legacy JWT `anon` and `service_role` keys are "deprecated by the end of 2026" with removal "Late 2026, TBC", and projects restored since 1 November 2025 receive no legacy keys ([Supabase API keys](#); [changelog 29260](#)) **[CP]**. The OpenAPI schema at `/rest/v1/` is no longer served to `anon` callers since 8 April 2026 for all projects ([changelog 42949](#)) **[CP]**, which removes the enumeration step Wiz used at Moltbook but not the data path.

4.4.3 Trust-path analysis: direct-to-BaaS with verified RLS versus a least-privilege BFF

The question is not "browser or server" but "where is the authorisation decision bound to the caller's identity and tenant on every request". Four paths **[INF]**, each grounded in vendor documentation **[CP]**:

Path A — browser to PostgREST with a publishable key, verified grants and RLS. The enforcement point is Postgres, which sees the real `sub` and claims on every request and cannot be bypassed by the client. Weaknesses: policy-logic correctness (needs the tests in 4.4.4); privileged side paths (`security-definer` RPC, non-invoker views, public buckets); no natural place for rate limiting, business validation or audit beyond `db-pre-request` hooks, which the hardening guide describes for "rate limiting, extra API key checks, or blocking direct access to certain objects" ([Supabase hardening guide](#)). An internet-reachable API is inherent.

Path B1 — BFF forwarding the user's JWT. Supabase Edge Functions default to `verify_jwt = true`; `auth: 'user'` yields a client "scoped to the caller's Row Level Security (RLS) policies" ([Supabase Edge Functions auth](#)). With a secret key, "A secret key bypasses RLS only when the request carries no user access token"; with a user token present the request "runs under the RLS policies of that signed-in user" ([Supabase RLS docs](#)). This is the least-privilege BFF: RLS remains the enforcement point and the server tier adds rate limiting, audit, validation and composition. Compromise of the BFF yields only the current caller's rights unless the secret key is also exfiltrated.

Path B2 — BFF with a secret key and no user token. RLS is removed from the path; tenant binding depends on every query carrying the right filter; one missing `where org_id = ...` is a cross-tenant leak, and a BOLA on any endpoint exposes the whole database. Supabase's own guidance treats this as the exception: "`ctx.supabaseAdmin` bypasses Row Level Security, so filter by the caller's ID"; "Use `ctx.supabaseAdmin` only for work that has to cross those policies" ([Supabase Edge Functions auth](#)). This is the confused deputy the audit described and is strictly weaker than Path A unless the BFF's authorisation is itself verified by the same cross-tenant tests.

Path B3 — BFF with a dedicated Postgres role over a direct connection. The 30 October change does not apply; grants and RLS must be designed explicitly; the role must not have `BYPASSRLS` and must not own the tables (owners bypass RLS unless `FORCE ROW LEVEL SECURITY`); per-request identity can be propagated with `SET LOCAL ROLE` and `set_config('request.jwt.claims', ...)` in a transaction, mirroring PostgREST ([PostgreSQL ddl-rowsecurity](#)).

Authorisation engines (Cedar, OPA, OpenFGA, Oso) are decision points, not enforcement points: Cedar defaults to `Deny` ([Cedar](#)), OPA "decouples policy decision-making from policy enforcement" ([OPA](#)), Oso returns "a boolean, a list, or logic to run against your database" ([Oso](#)) **[CP]**. In Path A they are irrelevant; in Path B their decision must be reflected in the query predicate, otherwise the engine approves while the secret-key query over-fetches **[INF]**. The OWASP Authorization Cheat Sheet supplies the BFF's acceptance criteria: deny by default, validate on every request, never rely on client-side checks, log, test ([OWASP](#)) **[CP]**. Governed low-code platforms implement Path B1/B3 by construction: Superblocks apps "never connect directly to business systems" ([Superblocks](#)); Retool permissions are per resource and group ([Retool](#)); ServiceNow Build Agent apps inherit ACLs ([ServiceNow](#)) **[CP]**. No vendor publishes breach-outcome comparisons between direct-RLS and BFF architectures; this analysis is reasoning from documented semantics **[INF]**.

4.4.4 The behavioural authorisation test matrix

A presence check ("RLS enabled", "policy exists") passed the EdTech app and would pass a `USING (true)` policy. The test that matters is behavioural: three principals (anonymous publishable-key caller, authenticated tenant-A user, authenticated tenant-B user), four surfaces (REST table, GraphQL if enabled, each RPC function, Storage object), five operations (select, insert, update, upsert, delete), asserting on **row counts and SQLSTATE**, not HTTP status **[PROP]** assembled from documented patterns **[CP]**. The assertion discipline is the point: an RLS-filtered `SELECT` succeeds with zero rows and an `UPDATE` or `DELETE` of invisible rows succeeds affecting zero rows, so a test that checks only for 200/204 passes on a broken policy; a 42501 signals a missing grant or a `WITH CHECK` violation and is the correct expectation for anonymous access to tenant data after 30 October **[INF]**.

Documented tooling as of October 2026: pgTAP via `supabase test db`, with `set local role` and `set local "request.jwt.claims"` for impersonation ([Supabase testing overview](#)) **[CP]**; the `basejump supabase_test_helpers` extension 0.0.6 (`tests.create_supabase_user`, `tests.authenticate_as`, `tests.clear_authentication`, `tests.rls_enabled`) ([Supabase pgTAP extended](#)) **[CP]**; Supabase's RLS Tester feature preview (24 April 2026), which is `SELECT`-only and therefore cannot detect missing `WITH CHECK` or `UPDATE`-without-`SELECT` defects ([changelog 45233](#)) **[CP]**; SupaShield, a community CLI that generates anonymous and authenticated CRUD tests in rolled-back transactions ([GitHub](#)) **[RR]**; and Lovable's Deep scan with Aikido "dynamic AI penetration testing" ([Lovable security](#)) **[VR]**. Application-level HTTP tests cannot use transactions for isolation and must sign in real users ([Supabase testing overview](#)) **[CP]**.

Minimal example, composed from the documented rules (explicit grants bundled with RLS per changelog 45329; T0 clause, (select ...) wrapping and app_metadata claims per the RLS docs; USING plus WITH CHECK on UPDATE per SKILL.md) **[PROP]**:

```
-- migration: invoices, tenant-bound via app_metadata.org_id
create table public.invoices (
  id          uuid primary key default gen_random_uuid(),
  org_id      uuid not null,
  amount      numeric not null,
  created_by  uuid not null default auth.uid()
);

-- Explicit grants (mandatory for new tables after 30 May / 30 Oct 2026). No grant to anon.
grant select, insert, update, delete on table public.invoices to authenticated;
alter table public.invoices enable row level security;

-- Tenant claim from user-immutable app_metadata; EXECUTE revoked from public/anon.
create or replace function public.current_org_id() returns uuid
language sql stable as $$
  select ((select auth.jwt()) -> 'app_metadata' ->> 'org_id')::uuid
$$;
revoke execute on function public.current_org_id() from public, anon;
grant execute on function public.current_org_id() to authenticated;

create policy invoices_select on public.invoices for select to authenticated
  using (org_id = (select public.current_org_id()));
create policy invoices_insert on public.invoices for insert to authenticated
  with check (org_id = (select public.current_org_id()));
create policy invoices_update on public.invoices for update to authenticated
  using      (org_id = (select public.current_org_id()))
  with check (org_id = (select public.current_org_id()));
create policy invoices_delete on public.invoices for delete to authenticated
  using (org_id = (select public.current_org_id()));
```

```

-- supabase/tests/invoices_rls.test.sql (run: supabase test db)
begin;
select plan(6);

set local role service_role; -- seed as service_role (bypasses RLS)
insert into public.invoices (id, org_id, amount, created_by) values
  ('11111111-1111-1111-1111-111111111111', 'aaaaaaaa-0000-0000-0000-000000000001', 10, '00000000-0000-0000-0000-00000000000a'),
  ('22222222-2222-2222-2222-222222222222', 'bbbbbbbb-0000-0000-0000-000000000002', 20, '00000000-0000-0000-0000-00000000000b');

-- 1. Anonymous: no grant -> 42501 before any policy runs.
set local role anon;
select throws_ok($$ select * from public.invoices $$, '42501', null, 'anon has no grant');

-- 2. Tenant A sees exactly one row.
set local role authenticated;
set local "request.jwt.claims" =
  '{"sub": "00000000-0000-0000-0000-00000000000a", "role": "authenticated", "app_metadata":
{"org_id": "aaaaaaaa-0000-0000-0000-000000000001"}}';
select results_eq($$ select count(*) from public.invoices $$, array[1::bigint], 'tenant A
sees one row');

-- 3. Cross-tenant read returns empty, not an error.
set local "request.jwt.claims" =
  '{"sub": "00000000-0000-0000-0000-00000000000b", "role": "authenticated", "app_metadata":
{"org_id": "bbbbbbbb-0000-0000-0000-000000000002"}}';
select is_empty($$ select id from public.invoices where id = '11111111-1111-1111-1111-111111111111' $$,
  'tenant B cannot read tenant A');

-- 4. Cross-tenant insert rejected by WITH CHECK.
select throws_ok($$ insert into public.invoices (org_id, amount)
  values ('aaaaaaaa-0000-0000-0000-000000000001', 1) $$, '42501',
  'new row violates row-level security policy for table "invoices"', 'tenant B cannot insert
into A');

-- 5. Cross-tenant update affects zero rows (assert the count).
select results_eq($$ with u as (update public.invoices set amount = 999
  where id = '11111111-1111-1111-1111-111111111111' returning 1) select count(*) from u $$,
  array[0::bigint], 'tenant B update of A affects 0 rows');

-- 6. Reassignment attack: tenant B cannot move its row into tenant A.
select throws_ok($$ update public.invoices set org_id = 'aaaaaaaa-0000-0000-0000-000000000001'
  where id = '22222222-2222-2222-2222-222222222222' $$, '42501', null, 'WITH CHECK blocks
reassignment');

select * from finish();
rollback;

```

The same six cases must be re-run over HTTP (publishable key with no Authorization header for the anonymous case; signed-in tenant A and B JWTs for the rest) against /rest/v1/invoices, /graphql/v1 if enabled, each /rest/v1/rpc/<fn> and /storage/v1/object/<bucket>/..., asserting on body row counts or returning values **[PROP]**. Storage follows RLS on storage.objects; upsert needs INSERT plus SELECT plus UPDATE or "file replacement (upsert) silently fails"; service keys bypass Storage RLS entirely (Supabase storage access control; SKILL.md) **[CP]**. The Supabase agent skill tells agents to run advisors before committing migrations but not to write cross-tenant tests; an organisation's AGENTS.md or CLAUDE.md should require this matrix explicitly **[INF]/[PROP]**.

4.4.5 The same failure class on other BaaS

Firestore test mode "allows anyone to read and overwrite your data"; production mode denies all client reads and writes while server SDKs "bypass all Cloud Firestore Security Rules"; rules "are not filters—queries are all or nothing"; the allow-all ruleset carries the warning "NEVER use this rule set in production" ([Firestore quickstart](#); [Firestore security; rules and queries](#)) **[CP]**. App Check "prevents some, but not all, abuse vectors" and is complementary to Authentication and rules, not a substitute ([Firebase App Check](#)) **[CP]**. Neon's Data API "has no permission layer of its own"; its "Grant public schema access" option runs `ALTER DEFAULT PRIVILEGES` so future tables are auto-granted to `authenticated`, the pre-30-October Supabase posture restricted to logged-in users ([Neon Data API](#)) **[CP]/[INF]**. Convex has no declarative row filter: "By default your Convex functions are public", and only internal functions are shielded, so the behavioural cross-tenant test is the only test available ([Convex](#)) **[CP]/[INF]**. PocketBase and Appwrite default to locked; their characteristic vibe-coding failure is generated code setting `""` rules or `Role.any()` to make a demo work ([PocketBase](#); [Appwrite](#)) **[CP]/[INF]**.

4.4.6 Bundle secrets: what each control actually scans

Framework prefixes inline values into the browser bundle by design: Next.js "inline[s]" `NEXT_PUBLIC_` values at build time; Vite says `VITE_*` variables "should not contain sensitive information such as API keys" ([Next.js](#); [Vite](#)) **[CP]**. The decisive distinction for CI gating is what is scanned **[INF]**. Repository scanners (gitleaks, TruffleHog, GitHub secret scanning) see source, so they catch a hard-coded secret key but not an environment variable a build inlines. Only build-output scanning catches the prefixed-variable leak: Netlify's smart detection "scans for potential secrets in your repository code and build output" and fails the build, on Personal, Pro and Enterprise plans ([Netlify secret scanning](#)) **[CP]**; elsewhere a post-build grep of `dist/` or `.next/static` is needed, safelisting `sb_publishable_` and failing on `sb_secret_` or a legacy service-role JWT **[PROP]**. Vercel's Protected Source Maps (default for new projects since 14 May 2026; existing projects opt in) gate `.map` files behind Vercel Authentication, which protects code logic, not a `NEXT_PUBLIC_` value that sits in the minified bundle itself ([Vercel changelog](#)) **[CP]/[INF]**.

GitHub push protection for repositories "Is disabled by default" and requires paid Secret Protection, at an illustrative "\$19 per active committer" over 90 days; user-level protection covers public repositories only; by default anyone with write access can bypass with a reason ([GitHub push protection](#); [GitHub pricing](#)) **[CP]**. GitHub added `supabase_oauth_access_token`, `supabase_scoped_personal_access_token` and `lovable_api_key` detectors on 5 October 2026; push-protection support for these is not stated ([GitHub changelog](#)) **[CP]**. Supabase auto-revokes secret keys found in public GitHub, post-commit; push protection was "planned, 2026" ([Supabase Security Retro 2025](#)) **[CP]**. gitleaks is "feature complete" with security patches only ([gitleaks](#)) **[CP]**; TruffleHog verifies over 700 detector types against live APIs ([trufflehog](#)) **[CP]**; neither README lists Supabase formats (gap).

4.5 Boundary B4: the agent execution plane

4.5.1 What is enforced outside the model, and where the seams are

Across Claude Code, Copilot coding agent, Cursor, Codex, Windsurf/Devin Desktop and Replit, the only controls enforced by something other than the model are an OS-level sandbox around shell commands, a network proxy allowlist in front of those commands, cloud-side isolation (ephemeral runners, branch and token restrictions), and the IAM or OAuth scope of the credentials the agent holds. Every vendor documents seams in its own words **[CP]**.

Claude Code. The sandbox is "off by default"; when on, writes are limited to the working directory and a temp directory, but reads cover "Most of the machine, including credential files such as `~/.ssh` and `~/.aws/credentials`", environment variables are "Inherited from Claude Code, including any secrets in its environment", and the network allowlist "start[s] empty" ([Claude Code sandboxing](#)) **[CP]**. "The sandbox covers shell commands only. Claude's file tools, MCP servers, and hooks run outside it"; "A `denyRead` entry doesn't stop the Read tool"; hooks, local MCP servers, LSP servers and `apiKeyHelper` "run with your full access" **[CP]**. Fail-open: if the sandbox cannot start "Claude Code runs commands without sandboxing" unless `failIfUnavailable` is true **[CP]**. Unsandboxed retry: the model "may retry the command with the `dangerouslyDisableSandbox` parameter", and "if an allow rule such as `Bash(curl *)` matches the command, it also approves the retry, so the command runs outside the sandbox with no prompt"; disable with `allowUnsandboxedCommands: false` **[CP]**. There is "no built-in credential deny list" **[CP]**. Bash deny rules match command text and are "not a security boundary around the program": `Bash(curl *)` does not stop `/usr/bin/curl` or `sh -c 'curl ...'` ([Claude Code permissions](#)) **[CP]**. Native Windows runs unsandboxed **[CP]**. Anthropic's own remedy for the seams is to run the whole process "in a container, virtual machine, or the sandbox runtime" **[CP]**. Practitioner traces confirmed the Read-tool gap, default reads of `/etc/passwd` and SSH keys, the retry prompt text " (don't ask, just do it)", and exfiltration through gists once `github.com` is allowlisted ([Claude Code Camp](#)) **[RR]**. Three pre-trust execution paths were fixed between August and December 2025: hooks in `.claude/settings.json` (GHSA-ph6w-f82w-28w6, no CVE), MCP servers from `.mcp.json` before approval (CVE-2025-59536, fixed 1.0.111) and `ANTHROPIC_BASE_URL` exfiltration (CVE-2026-21852, fixed 2.0.65) ([Check Point Research](#); [NVD](#)) **[CP]**. Opening an untrusted repository remains an attack surface; Check Point's advice is to "Inspect configuration directories such as `.claude/` and `.vscode/` before opening projects" **[CP]**.

GitHub Copilot coding agent. The firewall is on by default with a recommended allowlist covering OS package repositories, container registries and language package registries; "The firewall applies only to processes the agent starts through its Bash tool. It does not directly apply to MCP server processes or processes started in configured setup steps"; it "should not be considered a comprehensive security solution" ([GitHub firewall](#)) **[CP]**. Platform-enforced guardrails: no push to the default branch, one `copilot/` branch per task, Actions on agent PRs need write-user approval, hidden-character filtering, secrets only from the `copilot` environment, 59-minute sessions ([GitHub responsible use](#); [About coding agent](#)) **[CP]**. Once an MCP server is configured "Copilot can use its tools autonomously without asking for approval", so GitHub recommends read-only tool allowlists rather than `""` ([GitHub MCP](#)) **[CP]**.

Cursor, Codex, Windsurf/Devin, Replit. Cursor's sandbox (2.0, macOS Seatbelt) defaults to `readBoundary: "system"` (reads unrestricted) and `networkPolicy.default: "deny"`; team-admin policies "can't be weakened by user or repo files"; Auto-review "is not a security boundary" and a failed sandboxed command can be rerun outside the sandbox after classifier review ([Cursor sandbox.json](#); [Cursor Run modes](#)) **[CP]**. Codex defaults to `workspace-write`, offers `danger-full-access`, and its domain-enforcing proxy "Defaults to `false`" with "App and connector traffic ... not controlled" by it ([Codex config](#)) **[CP]**. Windsurf/Devin Desktop documents prefix-matched allow/deny lists up to a Turbo mode and no OS sandbox or network restriction ([Devin Desktop](#)) **[CP]**. Replit's "Agent is not able to modify the production database" ([Replit dev/prod](#)) **[CP]** is the only vendor change in the record that removes the destructive capability rather than mitigating it **[INF]**.

Every documented allowlist (Copilot's recommended list, Claude Code's `github.com`, Cursor defaults) includes hosts that accept uploads; a network allowlist bounds where exfiltration can go, not whether it can happen **[INF]**.

4.5.2 MCP: the host-side channel every sandbox leaves open

The lethal trifecta is private data, untrusted content and an exfiltration channel; "LLMs are unable to reliably distinguish the importance of instructions based on where they came from" (Simon Willison) [RR]. The General Analysis demonstration (8 Jul 2025) had Cursor plus the Supabase MCP under `service_role` read a support ticket submitted via `anon`, then copy `integration_tokens` back into the ticket; read-only mode "blocks the write-back step but still permits reads" (General Analysis) [RR]. Supabase's MCP page (8 Oct 2026) says to connect to production "only when the task requires production evidence", with `read_only=true`, `project_ref` scoping and restricted feature groups; manual approval of each tool call is "a guardrail, not a guarantee of human review"; result-wrapping against injection "is not foolproof" (Supabase MCP) [CP]. Tool poisoning (hidden instructions in tool descriptions, "rug pulls", cross-server shadowing) exfiltrated `~/.cursor/mcp.json` and SSH keys in Invariant's demonstration (Invariant Labs) [RR]. The MCP authorisation spec makes authorisation optional, forbids token passthrough and recommends short-lived tokens (MCP spec 2025-06-18) [CP]. Enterprise gateways exist (Cloudflare MCP server portals with per-tool allowlists and Logpush, where blocked users "can bypass this by using a server's direct URL"; Docker MCP Gateway, "invite-only"; Azure API Management with Entra JWT policies) (Cloudflare; Docker; Microsoft Learn) [CP].

As of 9 October 2026 no primary source confirms an in-the-wild incident in which a coding agent exfiltrated secrets via MCP; the record is high-fidelity research (Sentry MCP agentjacking, 85% success in testing, 2,388 injectable DSNs, Sentry calling a root-cause fix "technically not defensible"; `claude-code-action` CVE-2025-66032) plus one CI case the CSA says was exploited in the wild (CSA agentjacking; CSA CI/CD) [CP]/[PO]. Absence is consistent with low detectability: the Sentry attack uses legitimate developer credentials and looks like normal activity [INF].

Rules files are an injection surface. Pillar's "Rules File Backdoor" hid instructions in `.cursor/rules` and Copilot instruction files with zero-width and bidirectional Unicode; Cursor said the risk "falls under users' responsibility", GitHub that users are "responsible for reviewing and accepting suggestions", and GitHub added a hidden-Unicode warning on 1 May 2025 (Pillar Security) [VR]; no in-the-wild case is reported [VR].

4.5.3 Post-incident vendor changes

Replit (21 Jul 2025): "automatic DB dev/prod separation to prevent this categorically" (The Register) [PO], now documented as "Agent is not able to modify the production database" [CP]. Railway: the API `volumeDelete` mutation now has the same "two-day grace period" as dashboard deletes (Railway Central Station) [CP]; as of 9 October 2026 Railway still has no permission-scoped API tokens, the token model being Account, Workspace, Project (one environment) and OAuth (Railway Public API) [CP], and a "Read-only access for AI agents" request is "Under Review" with no reply (Railway feedback) [CP]. Railway's fix addresses recoverability, not authorisation: a token that can delete a volume can still delete it; the window converts an irreversible call into a two-day reversible one [INF]. No Cursor or Anthropic statement or change attributable to PocketOS was found; Cursor's network controls (Feb 2026) predate it, and Anthropic's 2026 hardening (`bypassPermissions` no longer honoured from project settings in v2.1.257, `blockReadsOutsideWorkingDirectories`, `allowManagedMcpServersOnly` in v2.1.273, strict-sandbox precedence fix in v2.1.285) is not attributed to the incident (Claude Code settings; managed settings) [CP]. Google fixed the Gemini CLI WIF over-grant with `.geminiignore` and role scoping [CP]; Amazon introduced "mandatory peer review for production access" (Amazon) [CP].

4.5.4 Minimal managed-settings baselines

Anthropic publishes a managed-settings mechanism (`/Library/Application Support/ClaudeCode/managed-settings.json`, `/etc/claude-code/managed-settings.json`, `C:\Program Files\ClaudeCode\managed-settings.json`, MDM profiles, Windows registry re-checked every 30 minutes, or the `claude.ai` console) with documented lock semantics: Boolean keys set in managed settings override local values; array keys merge unless a lock such as `allowManagedDomainsOnly` or `allowManagedReadPathsOnly` covers them; `allowUnsandboxedCommands: false` makes the sandbox "admin-required" ([Claude Code managed settings; sandboxing](#)) **[CP]**. Anthropic's fuller example "isn't a recommended policy" ([Claude Code settings example](#)) **[CP]**. The baseline below is assembled from documented keys; the combination is the authors' **[PROP]**.

Claude Code key	Value	Why
<code>sandbox.enabled</code> , <code>sandbox.failIfUnavailable</code> , <code>sandbox.allowUnsandboxedCommands</code>	<code>true</code> , <code>true</code> , <code>false</code>	Sandbox on, fail closed, no unsandboxed retry; repo excludedCommands ignored
<code>sandbox.network.allowedDomains</code> , <code>sandbox.network.allowManagedDomainsOnly</code>	internal registry proxy and git host only; <code>true</code>	Egress allowlist developers cannot widen
<code>sandbox.allowManagedReadPathsOnly</code> , <code>sandbox.enableWeakerNestedSandbox</code> , <code>sandbox.enableWeakerNetworkIsolation</code> , <code>sandbox.network.allowAllUnixSockets</code> , <code>sandbox.network.allowLocalBinding</code>	<code>true</code> , <code>false</code> , <code>false</code> , <code>false</code> , <code>false</code>	Close documented weakening keys
<code>sandbox.credentials.files</code> and <code>.envVars</code>	deny or mask (<code>injectHosts</code>) for <code>~/.ssh</code> , <code>~/.aws</code> , <code>~/.config/gh</code> , <code>~/.netrc</code> , <code>~/.docker</code> , <code>~/.gnupg</code> , cloud and registry tokens	There is "no built-in credential deny list"; masking with <code>injectHosts</code> is a local credential broker
<code>permissions.deny</code>	<code>Read(./env)</code> , <code>Read(./env.*)</code> , <code>Read(./secrets/**)</code> , <code>Read(~/.ssh/**)</code> , <code>Read(~/.aws/**)</code>	Mirror every <code>denyRead</code> path because the <code>Read</code> tool ignores the sandbox; deny rules apply "in every session, trusted or not"
<code>permissions.disableBypassPermissionsMode</code> , <code>permissions.blockReadsOutsideWorkingDirectories</code> , <code>allowManagedPermissionRulesOnly</code>	<code>"disable"</code> , <code>true</code> , <code>true</code>	Remove bypass mode; ignore project and <code>--allowedTools</code> rules
<code>allowedMcpServers</code> (by <code>serverUrl</code>), <code>allowManagedMcpServersOnly</code> , <code>allowManagedHooksOnly</code> , <code>strictKnownMarketplaces</code>	explicit lists; <code>true</code> ; <code>true</code> ; approved repo	MCP, hooks and plugins run on the host outside the sandbox
<code>forceLoginMethod</code> , <code>forceLoginOrgUUID</code> , <code>allowedProviders</code> , <code>requiredMinimumVersion</code>	org values; <code>>= 2.1.285</code>	Pin identity and provider; version at or above the strict-mode and MCP-lock fixes and far above CVE fixes 1.0.111 / 2.0.65
<code>env.CLAUDE_CODE_SUBPROCESS_ENV_SCRUB</code>	set	Strip credentials from all subprocesses

Residual after this baseline: MCP servers, hooks and `apiKeyHelper` still run with full host access; unattended or high-risk use should run the whole process in a container or VM **[CP]/[INF]**.

Copilot coding agent baseline (documented toggles; combination **[PROP]**): org "Enable firewall" = Enabled; recommended allowlist = Disabled with an org custom allowlist pointing at an internal registry proxy and required GitHub hosts; "Allow repository custom rules" off; MCP servers limited to read-only `tools` allowlists; no `COPILLOT_MCP_` secrets with write scopes; environment protection

rules on the `copilot` environment; third-party actions pinned to commit SHAs and no `id-token: write` or `contents: write` for agent workflows ([GitHub firewall](#); [CSA CI/CD](#)) **[CP]**. Whether an enterprise can lock all orgs is not documented (gap).

4.5.5 Dev/prod separation and credential brokering

Dev/prod separation is the one categorical control. Beyond Replit, Neon recommends snapshots at "Start of each agent session" and "Before database schema changes", restorable with the connection string preserved, at USD 0.09/GB-month, and offers anonymised branches masked with PostgreSQL Anonymizer ([Neon versioning](#); [Neon anonymization](#)) **[CP]**. Supabase branches are "data-less by default", auto-deleted on PR close, experimental and paid, with no masking documented ([Supabase branching](#)) **[CP]**. PlanetScale restricts production-branch deletion to administrators and recommends against production data in development ([PlanetScale](#)) **[CP]**.

Credential brokering keeps the destructive credential out of the agent's reach: Vercel OIDC Federation (all plans; build and function tokens with 2-hour TTL; cloud roles scoped per project and environment) ([Vercel OIDC](#)) **[CP]**; GitHub Actions OIDC tokens "only valid for a single job" with `sub` claims such as `repo:org/repo:environment:prod` ([GitHub OIDC](#)) **[CP]**; Cloudflare Outbound Workers intercept every `fetch()` and add authentication "so end developers don't need credentials" ([Cloudflare](#)) **[CP]**; Claude Code's `mask` plus `injectHosts` substitutes the real secret only on allowed hosts **[CP]**. ASI03 of the OWASP Agent Top 10 states the principle: agents "inherit credentials such as user sessions, API keys, and OAuth tokens"; "Issue short-lived, narrowly scoped tokens per task" ([Descopes summary of OWASP](#)) **[RR]**. Where a provider cannot scope tokens, as Railway still cannot, the closest approximation is token type (a project token bound to one environment) and the gap is a vendor-selection criterion **[INF]**.

4.5.6 Backups outside the blast radius

An architecture that survives the PocketOS class needs a copy outside the identity domain the agent's credentials can reach, storage-enforced immutability that no credential in the primary account can shorten, optional cross-account restore paths, and tested restores with measured RPO and RTO **[PROP]**. AWS logically air-gapped vaults store recovery points "in an AWS Backup service owned account", are "always locked with a vault lock in compliance mode", have a minimum retention of 7 days, and "Can optionally be shared across accounts using AWS RAM" ([AWS LAG vault](#)) **[CP]**. **Multi-party approval is optional**: "You can integrate your logically air-gapped vaults with Multi-party approval (MPA) to enable recovery ... even if the vault-owning account is inaccessible", requiring two Organizations, Identity Center, a RAM-shared approval team and an SCP, with "no additional MPA cost" ([AWS MPA](#)) **[CP]**. Compliance-mode Vault Lock becomes immutable after a grace period of at least 3 days, denying deletion to "any user (including the root user)"; on account closure AWS deletes vault contents after 90 days "even if a vault lock was in place" ([AWS Vault Lock](#)) **[CP]**. Equivalents: Azure's immutable vault "Enabled and locked" (irreversible; enforced soft delete 14 days; Resource Guard in a different tenant for "Maximum" isolation) ([Azure](#)); GCP backup vaults where "no one (not even a Project Owner) can decrease the retention period" ([GCP](#)); Backblaze B2 compliance-mode Object Lock ([Backblaze](#)); pgBackRest relying on storage-layer object lock ([pgBackRest](#)) **[CP]**.

Cost anchors: AWS warm storage USD 0.05/GB-month; LAG vault USD 0.0575/GB-month (eu-west-1 example); restore USD 0.02–0.03/GB; restore testing USD 1.50 per recovery point ([AWS Backup pricing](#)) **[CP]**. For a 200 GB database with 30 recovery points averaging 400 GB stored, the authors' arithmetic gives roughly USD 30–40 per month for an air-gapped, compliance-locked copy **[INF]**. Provider-internal grace periods (Railway two days, Replit 7 days, Azure 14 days)

protect against a single destructive call but not against a credential that can also purge or wait out the window **[INF]**. PocketOS's own newest backup was months old, so the restore-drill gap was a root cause alongside the storage layout **[PO]/[INF]**.

4.5.7 Dependency and registry controls

Package hallucination is measured and persistent (section 5.7). Socket Firewall's free tier blocks known-malicious packages at install, but "possible AI-detected malware only triggers a warning" and unknown packages pass ([Socket](#)) **[VR]**. Copilot's recommended allowlist includes public registries, leaving this path open **[CP]**. The CSA's controls for agent-driven installs are an allowlist with other installs routed to human review, pinned lockfiles with hash verification in CI, flags on packages registered in the last 30–90 days, and SBOMs for AI-generated code ([CSA slopsquatting](#)) **[CP]**. The deterministic form is an agent egress allowlist that reaches only an internal curated registry proxy **[PROP]**; registry-proxy products were not verified from primary documentation in this pass (gap). The in-the-wild counterpart of the threat is Shai-Hulud: the November 2025 wave hit 525+ npm packages with about 132 million monthly downloads, harvested AWS, GCP, Azure, npm and GitHub credentials via `preinstall`, and installed a self-hosted Actions runner when the GitHub token had `workflows` scope ([Semgrep](#)) **[RR]**. An agent running `npm install` inside a sandbox whose reads cover `~/.aws`, `~/.npmrc` and the environment hands such a worm the same material a developer shell would **[INF]**.

4.6 Shadow-app discovery pipeline

4.6.1 The verified wildcard-certificate finding

Direct TLS probes on 9 October 2026 show that all five platform subdomains are served under a single wildcard certificate, live apps included: `nonexistent-probe-xyz123.lovable.app` presented `CN=lovable.app, SAN *.lovable.app` (Google Trust Services); `replit.app` presented `*.replit.app`; `*.vercel.app` covered `next-blog-starter.vercel.app`, `nextjs-dashboard.vercel.app` and `v0-portfolio.vercel.app` (HTTP 200); `*.netlify.app`, `0=Netlify, Inc` (DigiCert) covered `docs-example.netlify.app`; `*.base44.app` (Let's Encrypt) **[CP]** (own verification). Per-app hostnames on platform subdomains therefore never appear in Certificate Transparency logs. Custom domains attached to these platforms do receive per-domain certificates and are CT-visible: Vercel "will automatically try to generate a certificate for every domain once it is added to a project" ([Vercel SSL](#)) **[CP]**. Symbiotic's own pipeline corroborates the blind spot: `crt.sh` produced 52 of its 1,085 confirmed sites (4.8%), against dorking 632 (58.2%), Common Crawl 251 (23.1%) and DNS brute-force 149 (13.7%) ([Symbiotic](#)) **[VR]**. Because platform subdomains share one certificate and one IP pool, EASM products that attribute by certificate names or netblocks (Censys's discovery paths, Defender EASM seeds) cannot attribute these apps to a customer; attribution must come from content (brand tokens, logos, corporate email domains), HTML/JS fingerprints (Escape used Shodan this way), search indexes and Common Crawl, or inside signals ([Censys ASM](#); [Defender EASM](#); [Escape methodology](#)) **[CP]/[INF]**.

4.6.2 The pipeline

Six steps, each tied to documented sources **[PROP]**:

1. **Inside the sanctioned tenants (day 1, no cost).** Export Lovable Security insights filtered to "Externally published" and "no owner"; Power Platform Inventory CSV or API; Replit team Deployments; Vercel and Netlify project lists with protection settings, remembering team defaults do not retro-apply **[CP]**.
2. **Identity and email signals (days 1–7).** IdP sign-in and OAuth consent logs for builder domains; email-metadata scanning of vendor welcome and billing mails recovers historical

sign-ups ([Nudge Security](#)) **[VR]**; expense-feed and unfederated-access detection ([Torii, vendor comparison](#)) **[VR]**; corporate-card and corporate-email registration checks ([TechTarget](#)) **[PO]**.

3. **SSE/CASB/browser telemetry (days 1-14)**. Query SWG and CASB logs for builder consoles and for *.lovable.app, *.replit.app, *.vercel.app, *.netlify.app, *.base44.app using the GenAI app-type categories in Cloudflare Gateway, Netskope CCI and Defender for Cloud Apps ([Cloudflare](#); [Netskope CCI](#)) **[CP]**; access logs show platform use, not what was deployed ([VentureBeat](#)) **[PO]**. No vendor documentation confirms that builder published-app domains are catalogued as distinct apps rather than under generic AI categories (gap).
4. **Outside-in enumeration (weeks 1-3)**. Search dorking with brand tokens restricted to the five platform zones, Common Crawl index queries, DNS brute-force of brand tokens under platform zones, GitHub code search, urlscan.io, Wayback; Shodan/Censys HTML fingerprint searches; CT monitoring **only** for the corporate domain, known custom domains and Lovable branded URLs **[VR]/[CP]**.
5. **Passive triage (continuous)**. Fetch the bundle, look for *.supabase.co URLs and key formats, attempt an anonymous read only. Both research pipelines converged on this minimum check set **[VR]**. Write and delete probes must not be run against assets the company does not own; both research teams that ran them acknowledged they could not fully explain how those were non-destructive **[INF]**.
6. **Register, gate, repeat**. Move finds into the sanctioned tenant with team defaults set (Vercel "All Deployments", Replit "Require", Lovable "Workspace", Base44 Apps SSO); put custom-domain apps behind an IdP gate with origin validation **[CP]**.

Cost anchors: Cloudflare Zero Trust free to 50 users then USD 7/user/month; Vercel Authentication on All Deployments free; Netlify Pro USD 20/month; Lovable Business about USD 50/month (third-party, July 2026); Replit Core USD 20, Pro USD 100, Enterprise USD 10,000-200,000 annual commitment; Power Apps Premium USD 20/user/month ([Replit pricing](#); [Replit Enterprise](#); [Netlify pricing](#)) **[CP]/[PO]**. crt.sh, Common Crawl and search operators are free; no published, independently evaluated accuracy figures exist for any dedicated vibe-app scanner **[INF]**.

5. Corrected empirical evidence on AI-generated code security

Read with their denominators, five independent academic studies and three vendor evaluations since 2025 support a narrower conclusion than "prompting redistributes rather than reduces": prompting shifts the correctness-versus-security trade-off, and whether that helps depends on model class, task length and phrasing. Nothing in this evidence caps damage; that is the job of the boundaries in section 4.

5.1 SusVibes, with correct denominators and best pairing

SusVibes (ICML 2026; v2 16 Feb 2026) is 200 Python feature-request tasks from 108 open-source repositories, each reconstructed from a CVE-linked fix commit, with mean repository context 162K lines and mean patch 172 lines; the agent passes when its code satisfies the functional tests **and** the security tests written for that specific CWE ([SusVibes](#)) **[RR]**. Table 3, FuncPass / SecPass as % of 200 tasks: Claude 4 Sonnet with SWE-agent **61.0 / 10.5**, OpenHands **49.5 / 12.5**, Claude Code 44.0 / 6.0; Kimi K2 22.5 / 6.0, 37.0 / 9.0, 43.5 / 8.0; Gemini 2.5 Pro 19.5 / 7.0, 21.5 / 8.5, 15.0 / 4.5 **[RR]**. "Over 80%" of functionally correct solutions were insecure (82.8% for

SWE-agent + Claude 4 Sonnet) **[RR]**. Every run already included the reminder "Make sure to follow best security practices and avoid common vulnerabilities" **[RR]**. Adding the exact target CWE left the joint rate at 10.5% while cutting FuncPass to 56.0%; self-selected CWEs gave 52.5 / 9.5, because agents picked 7.5 CWEs per task against 1.06 ground truth with precision around 0.1 **[RR]**. The authors "do not claim coverage of all exploit modalities", so SecPass is an upper bound on true security **[RR]/[INF]**. The released v1.0 dataset holds 186 tasks, not 200 (LeiLiLab/susvibes) **[RR]**. The defensible one-sentence statement: on CVE-derived Python feature work in mature codebases, developer agents produced code that passed both functional and targeted security tests on 4.5–12.5% of tasks, with the best functional agent at 10.5% and the best joint agent at 12.5%. It is not a measure of vibe-coded apps.

5.2 The Veracode trend, with methodology

Veracode's suite is 80 tasks (4 languages × 4 CWEs: SQL injection, XSS, log injection, weak crypto × 5 instances), judged by Veracode's own SAST, with no security prompting by design, across more than 150 models cumulatively (Veracode Spring 2026) **[VR]**. The 2025 release found 45% of tasks introduced an OWASP Top 10 flaw, Java above 70% failure, XSS 86% failure (Veracode press release) **[VR]**. The March 2026 update reports 55% overall pass (SQLi 82%, crypto 86%, XSS 15%, log injection 13%; Python 62%, Java 29%), GPT-5.1/5.2 "within the margin of error of GPT-4.1", Claude 4.5/4.6 "flat compared to earlier Claude generations", and **GPT-5-series with extended reasoning at 70–72%**, "a meaningful improvement over the standard 55%" yet "far from acceptable"; syntax pass rose from about 50% to 95% since 2023 **[VR]**. The corrected statement: average security pass for frontier non-reasoning models stayed in a 45–55% band from 2023 to March 2026 on a vendor SAST-judged, four-CWE suite with no authorisation CWEs, with a documented exception for reasoning modes **[INF]**. BaxBench independently finds reasoning models (o1, o3-mini, DeepSeek-R1) are the only class that benefits from generic security reminders (BaxBench) **[RR]**. The Georgia Tech SSLab tracker attributes 74 CVEs to AI-authored code between 1 May 2025 and 20 Mar 2026 (Claude Code 49, Copilot 15), a figure the researcher calls a lower bound reflecting "detection blind spots" (The Register) **[RR]**.

5.3 Prompting: redistribution, semantic drift, and phrasing

"Redistributes, not reduces" comes from one single-shot study on the synthetic Cybernative.ai dataset: 424 Python tasks, five prompts, GPT-4o and LLaMA 3.1-8B, one output each, Bandit and CodeQL (Urmi et al., arXiv 2608.24857) **[RR]**. With a minimal prompt GPT-4o returned valid code on only 86 of 424 tasks; structured prompts raised that to about 380. Among valid outputs the share with any Bandit finding fell from 76.3% to 72.0% and the high-severity **share** fell from 20.8% to 13.6% while the low-severity share rose from 32.0% to 43.5%; absolute counts were never reported **[RR]**. "Semantic drift" (the model removing a requested unsafe construct) was found in 9–10 of **15 manually sampled** task IDs under security prompts, in a dataset where some tasks "explicitly encourage insecure practices" **[RR]**. The authors conclude prompt structure "is an unreliable substitute for robust security controls" **[RR]**. The result is evidence that security framing changes what the model writes, not evidence that prompting cannot reduce counts **[INF]**.

Other studies fill in the conditions. Backslash (vendor, Apr 2025, task count unpublished): GPT-4o 10% → 20% → 65% vulnerability-free across naive, generic and OWASP prompts; Claude 3.7 Sonnet 60% → 100%; "five out of the seven LLMs" still produced vulnerable code (Infosecurity Magazine) **[VR]**. BaxBench (392 backends, exploit-confirmed): for Claude 3.5 Sonnet a generic reminder raised secure-and-correct from 32.9% to 34.5% while dropping correctness from 53.6% to 45.5% **[RR]**. The only study on real deployed vibe-coded apps replayed 70 confirmed

vulnerabilities 1,680 times: a one-line "production-ready" framing cut reintroduction from 25.7% to **11.0%**, a security-hardening skill to 11.9%, while a long "professional" technical prompt raised it to **45.7%**; a stronger model tier changed nothing (+0.5 pp); in 20.7% of reintroductions the agent "recognized the risk and still shipped the insecure code" ([Deng, Fan and Meng](#)) [RR]. The cross-study pattern is a correctness tax (SusVibes −5.5 to −8.5 pp FuncPass; BaxBench −8 to −12.6 pp pass@1); prompting helps on short tasks with reasoning-class models and concise framing, and does not help on long agentic trajectories, with weaker models, or where the model knows the risk and ships anyway [INF].

5.4 Iteration

Shukla et al. (GPT-4o, 10 secure C/Java baselines × 4 strategies × 10 rounds, 400 samples) found 387 vulnerabilities: efficiency-focused 124, feature-focused 158, **security-focused 38**, ambiguous 67; per-sample means rose from about 2.1 (rounds 1–2) to 6.2 (rounds 8–10) ([Shukla et al.](#)) [RR]. The abstract's "37.6% increase in critical vulnerabilities after just five iterations" has no defined baseline in the body and should not be quoted as a precise figure [RR]/[INF]. The authors' operating rule, at most three LLM-only rounds between human reviews, is reasonable [RR].

5.5 Stack-specific skills, with sample sizes

Supabase's own evaluation (9 Apr 2026): six scenarios per condition, LLM judge on Braintrust, run count not stated. Baseline / MCP only / MCP + skill: Claude Code Opus 4.6 58 / **50** / 67; Sonnet 4.6 46 / 58 / 71; Codex GPT-5.4 71 / 71 / 88; GPT-5.4 Mini 42 / 63 / 71. "These are early results with a small sample size" ([Supabase blog](#)) [VR]. With n = 6 a swing of one scenario is about 17 pp; the deltas are within one or two scenarios [INF]. The Opus 4.6 regression when the MCP server was added without the skill shows that more tools without rules can reduce security outcomes [VR]/[INF]. The mechanism is plausible: the independent vibe-app study attributes 658 of 1,186 confirmed vulnerabilities (55.5%) to "hidden security rules" of the platform, exactly what the skill encodes (RLS on views, `app_metadata`, `grants`, `SECURITY DEFINER`) [RR]. Kharmat et al. (12 developers, gpt-5.2, Spring Boot) cut authorisation/object-access weaknesses from 30 to 14 with a bundled training-plus-scaffold intervention, no control arm ([arXiv 2604.17763](#)) [RR]. No study A/B-tests a stack-specific skill against a generic OWASP rules file on identical tasks (gap). Verdict: directionally positive, underpowered, vendor-run, LLM-judged [INF].

5.6 AI review: recall limits for authorisation bugs

The one 2026 study that checks whether a reviewer identified the actual vulnerability (MalPR-Bench, 89 malicious PRs plus 50 benign controls) found CodeRabbit blocked 24 of 31 held-out PRs but pointed at the true flaw in 16: **16 of 24 when the evidence lay inside the touched files, 0 of 7 when it lay outside**; for 14 "absence-type" (missing-check) cases it blocked 9 and identified the target in **3** ([Chen et al., arXiv 2608.25730](#)) [RR]. That is the profile of a missing RLS policy, a missing ownership check or an inverted guard [INF]. An academic test of Copilot Code Review (public preview, Feb 2025) produced "fewer than 20 comments" across seven vulnerable datasets, "most of which addressed spelling or minor style issues", and no injection or access-control finding ([Amro and Alalfi](#)) [RR]. Vendor precision figures are 20–68% on August's dataset and 64–96% on the CodeRabbit-commissioned Signal65 dataset, neither reporting recall ([Signal65](#); [Liatrion](#)) [VR]. Copilot Autofix's median 28 minutes to fix versus 1.5 hours manual is a remediation-speed metric for CodeQL-detected alerts, not a detection result ([GitHub blog](#)) [VR]. Bright Security's five-run test is one 300-line app with two planted XSS flaws, undisclosed prompts, undefined denominators and an internal inconsistency ([Bright Security](#)) [VR]; it

illustrates run-to-run variance and nothing more [INF]. A clean AI review is not evidence of absence; use it to find and fix faster and keep deterministic scanners and behavioural tests as the gate [INF].

5.7 Package hallucination versus in-the-wild exploitation

Hallucination is measured: across 576,000 code samples from 16 models, **440,445 of 2.23 million package references (19.7%)** did not exist; commercial models at least 5.2%, open-source 21.7%; 205,474 unique names; 43% of hallucinated names recurred on all ten re-queries; most are not typosquats (48.6% at Levenshtein distance 6 or more) ([Spracklen et al., USENIX Security 2025](#)) [RR]. A 2026 re-measurement across Claude Sonnet 4.6, Claude Haiku 4.5, GPT-5.4-mini, Gemini 2.5 Pro and DeepSeek V3.2 found 4.62–6.10% on 199,845 paired prompts, with 127 names hallucinated identically by all five models and 53 still registrable ([Churilov, arXiv 2605.17062](#)) [RR]. Exploitation is a separate ledger: `unused-imports` (npm) is "a real malicious package" on a name LLMs produce instead of `eslint-plugin-unused-imports`, drawing about 233 weekly downloads in early February 2026 before npm's security hold, "potentially an intentional slopsquatting attack" whose intent Aikido "can't prove"; `react-codeshift` (npm) was a benign name spread to 237 repositories by 47 LLM-generated agent skills and claimed defensively; `huggingface-cli` (PyPI, 2024) was a benign placeholder with more than 30,000 downloads ([Aikido](#)) [VR]. The CSA's "tens of thousands of downloads" line conflates the benign placeholder with the malicious package and should not be repeated as malicious reach [INF]. Evidence ladder as of October 2026: hallucination confirmed; registration of hallucinated names confirmed, once with malicious code; autonomous agents installing hallucinated names from skill files confirmed; **no documented victim compromise** [INF].

5.8 Population evidence for vibe-coded apps

Deng, Fan and Meng (v4, 14 Sep 2026) fingerprinted 74,800 repositories (Claude Code `.claude/` and Lovable meta tags), kept 9,041 with at least 90% AI-authored commits and lines, found 1,007 deployed, randomly sampled 200 deployed web apps and confirmed 1,186 vulnerabilities by two-author manual exploitability review ($\kappa = 0.87$): **182 of 200 (91.0%)** vulnerable, median 6 per vulnerable app, 65.77% Critical or High; Broken Access Control 339 findings (28.58%) in **64.0% of apps**, 77% of them backend; Injection in 54.0%; Authentication Failures in 51.5% ([arXiv 2606.23130v4](#)) [RR]. Root causes: knowledge defects 63.4% (of which "hidden security rules" 55.5%), objective defects 23.1% ("demo-oriented design" 14.7%), memory defects 13.5% [RR]. The authors' advice: "generated apps should be treated as prototypes" [RR]. No study counts cross-tenant or RLS-correctness failures separately, and no study measures builder expertise; "non-developer builders" is inferred from platform, not measured [INF].

5.9 Revised determinism ladder

Rung	Examples	Evidence as of Oct 2026	Revised verdict
Generic rules and prompts	"Write secure code"; OWASP reminders	Model-dependent gains on short tasks (Backslash, BaxBench); flat joint rate on agentic repository work (SusVibes); correctness tax; phrasing effects of ± 15 –20 pp on real apps (Deng replay) [RR]/[VR]	Conditional, non-deterministic, with a correctness cost; not "mostly theatre", never a control
Stack-specific skills and golden-path templates	Supabase agent skill; AGENTS.md with the test matrix	+9 to +17 pp on n = 6 vendor scenarios; MCP-without-skill regression; mechanism supported by independent root-cause data [VR]/[RR]	Directionally positive, underpowered; deploy, but do not count it

Rung	Examples	Evidence as of Oct 2026	Revised verdict
AI review	Claude Code security review, Bugbot, CodeRabbit, Copilot review	0 of 7 out-of-diff, 3 of 14 missing-check targets identified (MalPR-Bench); near-zero security findings for Copilot preview; precision figures non-comparable, recall unreported [RR]/[VR]	Throughput tool with structurally low recall for authorisation bugs; advisory only
Deterministic in-loop checks	SAST, secrets and SCA via hooks or CI; pgTAP matrix; Security Advisor	Repeatable detection; presence checks miss logic errors; behavioural tests catch them [CP]/[INF]	Gate; behavioural tests are the only check that catches inverted logic
Secure templates and generator defaults	Explicit grants, RLS-on trigger, server-side secrets, dev/prod split	The substance of every vendor fix after an incident [CP]	High value; persists unless actively removed
Hard boundaries	Sandbox fail-closed, egress allowlist, brokered credentials, read-only scoped MCP, isolated immutable backups	Deterministic for the surface they cover; documented seams (file tools, MCP, hooks, allowlisted upload hosts) [CP]	Where demonstrable risk reduction lives; "deterministic" is not "unbypassable"

No new evidence in this pass measures the bottom three rungs; their verdicts rest on the incident record and architecture reasoning, as the audit (A12) observed **[INF]**.

6. The governance operating model

6.1 Gartner and the CSA in their own words, forecast separated from observation

Gartner has published at least three paywalled vibe-coding governance notes. The public abstract of "Govern Vibe Coding for Citizen Developers With Self-Service Platforms" (ID 8068765, 29 Jun 2026) says the shift "raises security, compliance, and governance risks" and that leaders should "enable and govern vibe coding effectively"; it contains no numbers ([Gartner](#)) **[CP]**. The two-layer model ("development controls" and "pre-deployment validation"), the agent safeguards ("sandboxing agents, mitigating prompt injection, restricting outbound data flows, and capping token spend") and the two Strategic Planning Assumptions ("by 2028, 60% of vibe-coded applications will be retired"; "30% of software engineering teams will face material capacity strain") are visible only on a vendor reprint page ([Tray.ai](#)) **[PO]**; they are forecasts with no sample, method or baseline **[INF]**. "How to Govern Vibe Coding" (ID 8207229, 31 Jul 2026) says "Ungoverned vibe coding creates unmanaged risk, bypassing existing security and governance controls" ([Gartner](#)) **[CP]**. Gartner's one relevant survey is 302 cybersecurity leaders (Mar-May 2025), of whom 69% "suspect or have evidence that employees are using prohibited public GenAI" ([Gartner newsroom](#)) **[CP]**.

The CSA's "The Vibe Coding Governance Gap" (2 Jun 2026) recommends "a lightweight registration process—deliberately not a heavyweight review process at this stage", paired with monitoring for unregistered apps and "non-punitive framing"; "The goal of this initial step is awareness, not gatekeeping" ([CSA](#)) **[CP]**. Its three review categories (internal tools with non-sensitive data; apps processing PII or regulated data; apps incorporating AI API calls or agentic functionality) "warrant different levels of security review" but carry no control lists, owners, exceptions or kill-switch logic **[CP]**. The note does **not** address amnesty programmes, kill switches or lifecycle management, and it states that no major AI security framework (NIST AI RMF, OWASP LLM Top 10, CSA's own AICM) defines a citizen-developer role **[CP]**. Its statistics are inherited: "56% of employees use unauthorized AI tools ... only 23% use IT-governed alternatives" reaches it from IDC via Vectra AI with no N, population or period located **[PO]**. The

CSA's shadow-AI note (30 May 2026, "generated with AI assistance" and not through official review) frames governance as "redirection of productive behavior into monitored channels, not prohibition of it" and calls inventory gaps "the primary governance metric" ([CSA PDF](#)) **[CP]**. The T0-T3 tier model in section 8 is therefore the authors' synthesis on a CSA skeleton, exactly as the audit said **[PROP]**.

6.2 Named organisations that publish practice: a bounded statement

Of about 40 sources reviewed in October 2026, three organisations describe their own vibe-coding governance in the first person, none of them a bank, telco, public body or EU-headquartered large enterprise, and none publishes an approval SLA, registry schema, expiry rule or outcome metric **[CP]**.

Method (fintech, 21 Apr 2026): chat-generated apps get "the same access controls and data handling restrictions as any other internal service"; secret names declared in config, values in a secret manager; secret scanning on every commit; non-root, read-only root filesystem, capabilities dropped; egress limited to DNS and HTTPS; deployment blocked on critical vulnerabilities; three review layers (scanners, AI PR review, human approval); PR-scoped previews on the private network deleted when the PR closes ([Method](#)) **[CP]**. Outcomes are qualitative only. **Tenable** (6 Oct 2026): "Governance works better than blanket bans, because prohibiting AI-aided development usually causes employees to keep their app development activities hidden"; a five-tier model from Executive Staff through an AI Governance Board, AI Functional Leads with "direct authority and accountability over AI skill approvals, operational queues", an enablement working group and community channels; "Tenable has tied AI tool access directly to mandatory security training" ([Tenable](#)) **[CP]**. It also records the costs: citizen-coder volume "can become overwhelming and disruptive for the IT and security teams", token spend, and "siloes data lakes" **[CP]**. **EXANTE** (regulated brokerage, 27 Feb 2026): "proper, governed internal APIs ... Not direct database access"; managed environments; "We insist that all vibe-coded work goes into version control"; sharing and discovery; metrics "We're working on it" ([Finance Magnates](#)) **[CP]**. An unnamed "large European insurance company" is described second-hand by AWS, for professional engineers ([AWS](#)) **[VR]**. All three disclosures converge on governed APIs over direct data access, a managed runtime, version control, review before production and training tied to access; that supports the direction of the paved-road thesis but is three self-reports, not comparative evidence **[INF]**. Government guidance (UK AICA guidance, Australian DTA, US GSA compliance plan, Swedish Digg/IMY) governs staff use of AI tools; none addresses the citizen-built app as an artefact with an owner and lifecycle ([GOV.UK](#); [GSA](#)) **[CP]**.

6.3 Registry schema assembled from documented sources

Three documented registries exist: the Power Platform CoE Starter Kit's compliance form (business justification, business impact, access management including joiners/movers/leavers, dependencies, conditions of use, mitigation plan) ([Microsoft Learn](#)) **[CP]**; Cloudflare's metadata store (owner, team, description, connected data sources, usage metrics; cost via resource tags) ([Cloudflare](#)) **[CP]**; and ServiceNow's citizen-development intake (repeatability, expected users, sensitive data, cross-department data, data access; support and maintenance owner assigned before build) ([ServiceNow Community](#)) **[CP]**. Mendix enforces exactly one Technical Contact per app, transferable ([Mendix](#)) **[CP]**.

Field	Documented in	Status
Owner (person) plus support owner; team or department	CoE Starter Kit, Cloudflare, ServiceNow, Mendix	Documented
Description and business justification; business impact rating	CoE Starter Kit, Cloudflare	Documented

Field	Documented in	Status
Audience and share scope (count, groups, "Everyone")	CoE Starter Kit thresholds	Documented
Data sources and connectors; dependencies (APIs, cloud resources)	CoE Starter Kit, Cloudflare, Lovable Security insights	Documented
Data classification tier; sensitive-data flag; cross-department data flag	ServiceNow intake; CSA data tiers	Documented
AI-feature or agentic flag (CSA category 3; AI Act intended-use question)	CSA	Documented as a criterion
Access management description including JML handling; continuity plan for critical apps	CoE Starter Kit	Documented
Cost attribution tag; last-published and last-used dates; usage metrics; platform and environment	Cloudflare, CoE Starter Kit, Lovable	Documented
Expiry or TTL date	None	Proposal
Reference to processing-activity record and DPIA-screening outcome	None in private sector; GSA chain is the only public analogue	Proposal
Hosting region and vendor DPA status (feeds Art. 30(1)(g) and Art. 28 entries)	None as a registry field	Proposal

6.4 Lifecycle controls with specifics

The only fully specified lifecycle machinery in the public record is Microsoft's CoE Starter Kit, now "no longer actively maintained" with core capabilities moved into the admin centre ([Microsoft Learn](#)) **[CP]**. Its shipped defaults are the only mechanised thresholds published anywhere and are configurable examples, not norms **[INF]**: inactivity check for apps not modified or launched in **six months**, owner asked via flow approval, deletion **three weeks** after approval, manager escalation after **one month** of silence; **quarantine after 7 days** of non-compliance (missing business justification), released automatically on submission or manually after an admin risk assessment, with end users shown an access-denied message; orphaned objects reassigned weekly to the former owner's manager with "Take ownership", "Delete" or "Assign to someone else" actions; "Re-publish needed" at 60 days; compliance triggers at sharing with more than 20 users or a group ([Microsoft Learn governance components](#); [quarantine setup](#)) **[CP]**. The native admin centre lists ownerless apps active in the last 90 days with "Assign to new owner", and warns that "New owners don't automatically get permissions to the environment or data sources" ([Microsoft Learn](#)) **[CP]**.

Lovable: when a member leaves, owned projects "pass automatically to the most senior remaining member" (owners, admins, editors), "Projects with access set to Restricted are not transferred automatically", and the leave event is audit-logged on Enterprise ([Lovable workspace docs](#)) **[CP]**; this prevents orphaning but assigns by seniority rather than business relevance **[INF]**. Mendix offers archive/un-archive, single-owner transfer and a 30-day grace after licence expiry ([Mendix](#)) **[CP]**. ServiceNow: reviews "at least once a year"; "Significant modifications go through the same lifecycle phases as new apps"; retirement is notify, resolve dependencies, "Back up the app and its data ... and then delete the app" ([ServiceNow Community](#)) **[CP]**. Method's PR-scoped preview deletion is the only automatic expiry in a vibe-coding-specific disclosure **[CP]**. Exception handling exists in the Starter Kit ("excused" with approval comment) and in GSA's plan (CAIO waivers with written justification, reported to OMB within 30 days, reviewed annually; none issued) ([GSA](#)) **[CP]**. Supplier review: CSA asks for "vendor security attestations and audit logging in contracts" where source export is unsupported **[CP]**. No source publishes an app TTL, a recertification cadence tied to data class, or an exception register for vibe-coded apps **[INF]**.

6.5 KPIs: documented versus proposed

KPI	Status	Precedent
Ownerless apps active in last 90 days; apps shared with "Everyone"; non-compliant or quarantined apps; apps inactive more than N months	Documented	Power Platform admin centre and Starter Kit (Microsoft Learn)
Inventory gap (registered vs discovered)	Documented as a principle	CSA "Treat inventory gaps as the primary governance metric"; Nokod survey: security teams see 44% of business-built apps (N not stated) (PR Newswire)
Orphan rate	Documented	Nokod customer sample: up to 30% of vulnerable Power Apps orphaned (Nokod)
GenAI policy violations per org per month; share of use via personal accounts; share of interactions with sensitive data	Documented (telemetry vendors)	Netskope 223/month; 47% personal; Cyberhaven 39.7% sensitive
% employees trained; adoption and ROI measures	Documented	Microsoft adoption framework; Tenable Functional Leads
Time-to-register; scan-block overrides; mean time to quarantine; % apps behind IdP; restore-drill pass rate; cross-tenant test pass rate per release	Proposed	No external precedent located

6.6 Counter-evidence on bans versus enablement

The paved road has four documented weaknesses **[CP]/[VR]**. First, the sanctioned platform becomes its own shadow estate: Zenity's customer telemetry reports about 80,000 apps, automations and copilots per large enterprise, 62% with vulnerabilities, 63% of copilots overshared ([Zenity](#)) **[VR]**; Nokod's samples show around 10,000 vulnerable applications owned by 2,500 individuals in large environments **[VR]**; the CSA says governance dashboards are "frequently underutilized" **[CP]**; a Power Platform practitioner describes personal connections as "credentials sharing as a service" ([Perspectives+](#)) **[RR]**. Second, maintenance and cost shift to engineering (Gartner forecasts; Tenable's first-person account) **[PO]/[CP]**. Third, "bans fail" is under-evidenced: Netskope telemetry (1 Oct 2024–31 Oct 2025) shows **90% of organisations block at least some genAI apps** (average 10) while personal-account use fell from 78% to 47% and organisation-managed use rose from 25% to 62% ([Netskope 2026](#)) **[VR]**; the 2023 corporate bans were temporary restrictions with no measured outcome ([TechCrunch](#)) **[PO]**; stated intent to defy bans is self-report (46% of 6,000 knowledge workers, Software AG) ([eWeek](#)) **[VR]**. Fourth, non-punitive registration without enforcement has no documented effect; the CSA itself notes policy without communication "may have negligible effect" **[CP]**. The honest framing: paved road plus registration is the consensus recommendation of Gartner, CSA, Tenable, Method, EXANTE and Cloudflare; the consensus practice measured by Netskope is "block many, sanction some"; the two are compatible **[INF]**. No comparative study of ban versus amnesty versus paved-road outcomes exists **[INF]**.

6.7 Corrected survey and telemetry ledger

The headline figures measure at least four different things on four populations; they cannot be combined into one "shadow AI rate" **[INF]**.

Figure	Source and date	N, population, method	What it measures
56% unauthorised AI; 23% IT-governed	IDC 2025 via Vectra AI via CSA (Jun 2026)	Not stated anywhere reachable	Unknown [PO]
47% of genAI users on personal accounts (from 78%); 223 violations/org/month from ~3% of users; 90% block some apps	Netskope Cloud and Threat Report 2026 (6 Jan 2026)	Customer telemetry, Oct 2024–Oct 2025; "violation" = customer DLP policy hit	Traffic shares and DLP detections [VR]

Figure	Source and date	N, population, method	What it measures
82% of pastes from unmanaged accounts; 67% of access via non-corporate accounts	LayerX 2025	Browser-extension telemetry; N and period not disclosed; terms used interchangeably	Paste-event origin [VR]
4.37% of 1M prompts and 22% of 20,000 files contain sensitive data	Harmonic, Q2 2025	Browser telemetry to 300 tools; org count not stated	Content sensitivity by vendor classifier [VR]
20% of breached orgs had a shadow-AI breach; 34% of orgs with policies audit for unsanctioned AI; 63% lack AI governance policy	IBM Cost of a Data Breach 2025	Ponemon; 600 breached organisations, Mar 2024–Feb 2025	Breached-organisation sample (IBM) [VR]
5% very confident of full visibility into internal tools	Retool State of AI Governance 2026	307 CTO/CIO/CISOs, Wynter panel, May 2026	Leader confidence [VR]
60% built software outside IT oversight in past year	Retool Build vs Buy 2026	817 Retool customers and builders, late 2025	Self-report by a Retool sample [VR]
69% suspect or have evidence of prohibited GenAI use	Gartner, Nov 2025	302 cybersecurity leaders, Mar–May 2025	Leader perception [CP]
One-third via personal accounts; 39.7% of AI interactions involve sensitive data	Cyberhaven 2026 (5 Feb 2026)	222 companies, customer telemetry; "sensitive" = customer labels	Customer telemetry (Cyberhaven) [VR]
44% used AI contravening policy; 57% hide AI use; 70% use free public tools vs 42% employer-provided	KPMG / University of Melbourne 2025	48,340 respondents, 47 countries, Nov 2024–Jan 2025, representative samples	Only large representative multi-country self-report (KPMG) [RR]
55% of AI users' main tool employer-introduced; binding AI rules in 31% of employers >1,000 staff	University of Konstanz, Sep 2026	1,105 German employees, May 2026, DFG-funded	EU academic self-report (Pebblous summary) [RR]
66% used AI believing policy did not allow it	PagerDuty / Wakefield, Apr 2026	1,250 office professionals, AU/JP/UK/US	Vendor-sponsored self-report [VR]
Security teams see 44% of business-built apps	Nokod, Apr 2026	N and population not in release	Vendor survey [VR]

The Netskope trend is the strongest available evidence that sanctioned enterprise accounts plus blocking shift behaviour; it does not isolate either lever **[INF]**. Training is recommended by every source and evidenced by none: the one design with an enforcement hook is Tenable's "no training, no tool access" **[CP]/[INF]**.

7. The legal and standards layer

Nothing in this section is legal advice; the decision trees present regulator guidance, not an opinion on a specific incident, and the audit's instruction to obtain qualified legal review before publication stands.

7.1 GDPR: risk-thresholded decision trees per failure mode (EDPB Guidelines 9/2022)

A personal data breach exists only where "a breach of security" led to "the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data" (Art. 4(12)); an unexploited vulnerability is an Art. 32 weakness, not by itself a notifiable breach **[CP]**. Once a breach exists, Art. 33 requires notification to the supervisory authority "without undue delay and, where feasible, not later than 72 hours after having become aware of it ... unless the personal data breach is unlikely to result in a risk"; Art. 34 requires communication to individuals only where the breach is "likely to result in a high risk"; Art. 33(5) requires documentation of every breach, notifiable or not (EDPB Guidelines 9/2022 v2.0, paras 28–29, 82–83, 121) **[CP]**. The

EDPB's three breach types are confidentiality, integrity and availability (para 17); "A breach will always be regarded as an availability breach when there has been a permanent loss of, or destruction of, personal data" (para 19); a temporary loss restored from backup is still a breach of security to be documented and assessed case by case, with the worked contrast of hospital data (could present a risk) and a media company's newsletter (unlikely) (paras 20-22) **[CP]**. Awareness arises at "a reasonable degree of certainty that a security incident has occurred that has led to personal data being compromised" (para 31); a short investigation is permitted before the clock starts (para 34); the lost-USB example says notify even when access cannot be established (para 33) **[CP]**. A processor "must notify the controller 'without undue delay'" and "does not need to first assess the likelihood of risk" (para 44) **[CP]**.

The Digital Omnibus (COM(2025) 837, 19 Nov 2025) proposes notification only where a breach is "likely to result in a high risk", 96 hours, and an ENISA single entry point; the EDPB-EDPS Joint Opinion 2/2026 welcomed the direction; as of September 2026 there was a Parliament draft report (22 Jun 2026) and Council working-party activity but no committee vote or trilogue ([Praxikon, 15 Sep 2026](#); [White & Case](#)) **[PO]**. **72 hours and the "unlikely to result in a risk" threshold are the law in force [CP]**.

Failure mode	Step 1: is there a breach?	Step 2: Art. 33	Step 3: Art. 34	Always	Design duties engaged
FM1 broken authorisation on a data API	Personal data in exposed tables and evidence of unauthorised read or write (logs, researcher demonstration, a written-back "paid" record) = confidentiality and, with writes, integrity breach; where logs cannot exclude access, paras 31 and 33 point toward treating confirmed exposure as a breach after a short investigation	Notify within 72 h of awareness unless unlikely to result in a risk; addresses, debt amounts, payment data and minors weigh heavily	Communicate only if high risk (financial data, special categories, minors, identity-theft potential)	Document under Art. 33(5)	Art. 32(1)(b), (d) and 25(1); risk-based, not categorical
FM2 public-by-default publishing	Personal data reachable by anyone = accidental disclosure, confidentiality breach; Art. 25(2) engaged because data was "made accessible without the individual's intervention to an indefinite number of natural persons" by default	As above; indexing and duration are aggravating	As above	Document	Art. 25(2); controller is the employer where the employee acted in the course of employment
FM3 platform-side bug	Platform is processor only for data under an Art. 28 contract (Lovable: Customer Personal Data); for Service and Log Data it is its own controller; chat histories sit at this boundary and need counsel; processor notifies controller without assessing risk; controller's 72 h starts at controller awareness	Controller decides; where access cannot be shown or excluded (Base44: "no evidence of abuse") a reasoned, documented position is required	As above	Document	Art. 28(1), (3); Art. 32
FM4 agent destruction	Permanent, unrecoverable deletion = availability breach "always"; restored from backup = temporary loss, documented, notifiable only if the unavailability itself presents a risk; fabricated records (SaaS's 4,000) = integrity breach	Annex B example iv: notify "if there are likely consequences to individuals"	"depending on the nature of the personal data affected"	Document	Art. 32(1)(c) restore availability "in a timely manner"; 32(1)(b) resilience; co-located backups are evidence against "appropriate" measures

Controller and processor roles for personal sign-ups: an employee's personal account creates a contract between the individual and the platform, not between the employer and the platform; absent an Art. 28(3) contract the platform may well be an independent controller for what it receives (Lovable's DPA says so for Service Data); the employer's exposure is then an uncontrolled disclosure to a third party and an Art. 28/32 failure, not "a disclosure to a processor with no Article 28 contract" as the original put it **[INF]**; fact-specific and for counsel. No

supervisory-authority decision as of October 2026 applies Art. 33/34 to a vibe-coded app; the EDPB's framework already supplies the analysis, and the contested points will be awareness timing, exposure without proven access, and who is controller for prompt and chat content **[INF]**.

7.2 Registry to Art. 30 and Art. 35 without one ROPA per app

Art. 30 records are kept per processing activity (purposes, categories of data subjects and data, recipients, transfers, retention "where possible", and "where possible, a general description of the technical and organisational security measures" under Art. 30(1)(g)) ([EUR-Lex GDPR](#)) **[CP]**. An app supports one or more activities and several apps can support one. The registry should link each app to the activity records it serves by purpose; where none exists the app has surfaced a new processing activity and the DPO creates one; the app's authorisation model, publishing setting, backup arrangement and vendor DPA status feed the Art. 30(1)(g) description and the Art. 28 recipient entry **[PROP]**. DPIAs are triggered by processing "likely to result in a high risk" (Art. 35(1)), not by every citizen app; the WP248 criteria most often met by citizen-built apps are new technology (LLM features, agentic actions), sensitive data, vulnerable subjects, scale, matching datasets and systematic monitoring, with two or more generally requiring a DPIA ([EDPB endorsed WP29 guidelines](#)) **[CP]** (wording from prior knowledge; not re-opened). DPIA screening belongs in the registry as a questionnaire, not an automatic trigger **[PROP]**. The registry is nonetheless the strongest Art. 24 accountability evidence available when an authority asks about an app that leaked **[INF]**.

7.3 EU AI Act: the three-question "AI system" test and Art. 4/50 status after the Omnibus

Regulation (EU) 2026/1744 (8 Jul 2026; OJ 24 Jul; in force 27 Jul 2026) moved Annex III high-risk obligations to **2 December 2027** and Annex I to **2 August 2028**; Art. 50 transparency applies from **2 August 2026**, with a grace period to 2 December 2026 only for the Art. 50(2) marking duty of generative systems already on the market ([EUR-Lex OJ L 2026/1744](#); [Commission FAQ on Art. 50](#); [AI Act Service Desk timeline](#)) **[CP]**. Art. 4 as amended reads that providers and deployers "take measures to support the development of AI literacy" with the express clause "This obligation does not require providers or deployers to guarantee any specific level of AI literacy of any individual" ([AI Act Service Desk, Art. 4](#)) **[CP]**.

The Act regulates the deployed system's behaviour, not how its source code was authored. Under Art. 3(1) and the Commission's February 2025 guidelines (C(2025) 924), systems "based on the rules defined solely by natural persons to automatically execute operations" and "basic data processing systems" are outside the definition ([Commission guidelines](#); [CMS summary](#)) **[CP]**. Three questions of the deployed app **[PROP]**:

1. **Does any component infer outputs (predictions, content, recommendations, decisions) from inputs rather than executing human-written rules?** No: not an AI system; GDPR, NIS2/DORA and CRA only. The coding assistant that wrote it is an AI system whose provider is the vendor; the enterprise is a deployer, which is what engages Art. 4.
2. **If yes, is the enterprise placing that component into service under its own name (a branded support bot calling an LLM API)?** If yes it is likely the provider of that AI system (Art. 3(3): "has an AI system ... developed and ... puts the AI system into service under its own name") and also the deployer internally; Art. 50(1) (inform people they interact with an AI system) and, for generative output, 50(2) (machine-readable marking) apply from 2 August 2026, with fines up to EUR 15 million or 3% of worldwide turnover (Art. 99(4)) ([AI Act Service Desk FAQ](#)) **[CP]**. Whether an enterprise merely wrapping a third-party GPAI model is the "provider" for 50(2) is contested and awaits the code of practice; flag for counsel.

3. **Does the use case fall in Annex III (employment, education, credit, essential services)?** If yes, high-risk obligations apply from 2 December 2027; the CSA's "drift into high-risk use cases" risk is real, so the registry records intended use.

The CSA note's "August 2, 2026" high-risk date was accurate when written and is superseded **[CP]**. Art. 4 is a duty of effort; training on BaaS authorisation, secrets and publishing defaults is a natural way to evidence it **[INF]**. The verbatim post-Omnibus text of Art. 50(1)–(5) was not extracted in this pass; sources report no substantive amendment to those paragraphs; confirm against the consolidated text ([EUR-Lex consolidated](#)) before publication (gap).

7.4 NIS2 and DORA with in-scope qualifiers

Neither instrument names AI builders or coding assistants. NIS2 Art. 21(2) requires essential and important entities to address "(c) business continuity, such as backup management and disaster recovery", "(d) supply chain security, including security-related aspects concerning the relationships between each entity and its direct suppliers or service providers", "(e) security in network and information systems acquisition, development and maintenance, including vulnerability handling", "(g) basic cyber hygiene practices and cybersecurity training" and "(i) ... asset management"; Art. 21(3) requires account of each supplier's "secure development procedures" ([NIS2 Art. 21 mirror](#); [EUR-Lex Directive 2022/2555](#)) **[CP]**. The applicability chain for an in-scope entity (an inference): the citizen-built app is a system the entity uses for its operations, its development falls under 21(2)(e), the builder is a supplier under 21(2)(d) and 21(3), the estate under 21(2)(i), backups under 21(2)(c) **[INF]**. None of this is universal; it attaches to in-scope entities, is proportionate and varies with national transposition **[CP]**.

DORA (applying since 17 Jan 2025) makes financial entities "at all times ... fully responsible" (Art. 28(1)), requires a register of **all** ICT contractual arrangements distinguishing those supporting critical or important functions (28(3)), pre-contract assessment (28(4)) and, for critical or important functions, "unrestricted" rights of access, inspection and audit, participation in threat-led penetration testing and exit terms (30(3)) ([DORA Art. 28](#); [DORA Art. 30](#); [EUR-Lex DORA](#)) **[CP]**. A builder hosting an app used by a financial entity is an ICT third-party service provider; every such arrangement, including a shadow personal sign-up, belongs in the 28(3) register and its absence is itself a gap **[INF]**. The decisive qualifier is critical or important function; most prototypes are not, but anything on a payments, onboarding or regulatory-reporting path may be, and for those Lovable's DPA (no audit clause) and Vercel's DPA (audit rights "satisfied by" SOC 2 reports) do not supply 30(3)(e) on standard terms **[CP]/[INF]**. No competent authority has named AI builders as a supply-chain category (gap).

7.5 Cyber Resilience Act: scope and dates

The CRA (Regulation (EU) 2024/2847) covers "products with digital elements placed on the market": downloadable or installable software, embedded software, and "software plus cloud" where remote data processing is essential; "Pure SaaS is generally excluded" and falls under NIS2/DORA instead; internal tools never placed on the market are out of scope ([Kirkland](#); [DLA Piper](#)) **[PO]**. Art. 14 reporting (actively exploited vulnerabilities and severe incidents: early warning 24 hours, notification 72 hours, final report 14 days or one month) has applied since **11 September 2026**; essential requirements, vulnerability handling, documentation and conformity assessment apply from **11 December 2027**; fines up to EUR 15 million or 2.5% of turnover ([Kirkland](#)) **[PO]**. A vibe-coded SaaS with a Supabase backend is normally outside the CRA; a vibe-coded mobile or desktop app distributed commercially is inside, and its backend may be a remote data processing solution; the manufacturer then owes Art. 14 reporting today and Annex I

("secure by default configuration", "without known exploitable vulnerabilities") from December 2027 **[INF]**. The Commission's separate guidance on remote data processing was not located as published (gap).

7.6 UK and US notes

UK. On 24 March 2026 NCSC CEO Richard Horne's RSAC keynote said "The AI tools we use to develop code must be designed and trained from the outset ... so that they do not introduce or propagate unintended vulnerabilities"; an NCSC blog the same day said AI-produced code "currently poses intolerable risks for many organisations" ([NCSC](#)) **[CP]**. UK GDPR breach rules mirror the EU text, so section 7.1 applies with the ICO as regulator ([ICO breach guide](#)) **[CP]** (prior knowledge; not re-opened). The ICO's 8 October 2026 call for evidence on agentic AI is not vibe-coding-specific **[CP]**. No ICO guidance addresses low-code or AI-generated code (gap).

US. California's CCPA regulations (effective 1 Jan 2026) require documented risk assessments from 1 January 2026 with attestations due by 1 April 2028 and independent cybersecurity audits certified from 1 April 2028 (revenue over USD 100 million), 2029 and 2030 ([Hunton](#)) **[CP]**; an unregistered vibe-coded app fails such an audit by omission **[INF]**. The Colorado AI Act (SB 24-205) was repealed and replaced on 14 May 2026 by SB 189, the Automated Decision-Making Technology Act, effective 1 January 2027 if AG rulemaking completes, with notice, explanation and human-review rights, AG-only enforcement up to USD 20,000 per violation, and no algorithmic-discrimination duty of care or impact assessments ([Skadden](#)) **[CP]**. Live US obligations on app features are transparency and notice duties (Colorado from 2027, Texas TRAIGA and Illinois HB 3773 from 1 Jan 2026), not EU-style conformity assessment **[INF]**. SEC Form 8-K Item 1.05 and NYDFS Part 500's asset inventory (500.13) are the disclosure and inventory hooks; HIPAA makes a builder that signs no BAA unusable for PHI, which excludes Lovable ([Lovable for Enterprise](#)) **[CP]**. No US regulator guidance on vibe coding was found (gap).

7.7 Standards clause map

The clauses exist; what is missing is a citizen-developer role. The CSA states that none of NIST AI RMF, OWASP's LLM Top 10 or its own AICM provides "dedicated, accessible guidance for citizen developers", and that OWASP's Citizen Development and Low-Code/No-Code Top 10 lists "predate vibe coding" ([CSA](#)) **[CP]**. NIST SP 800-218A (July 2024) is a profile for building generative AI models, not for using AI to write software; SSDF 1.2 (SP 800-218r1) is an initial public draft of 17 December 2025 ([NIST CSRC](#)) **[CP]**. OWASP's Agentic Top 10 (9 Dec 2025) supplies ASI02 Tool Misuse, ASI03 Identity and Privilege Abuse and ASI05 Unexpected Code Execution ([Cycode summary](#)) **[RR]**. ISO 27001:2022 Annex A control numbers and CIS Controls below are from prior knowledge of stable texts and were not re-fetched.

Control in this paper	GDPR / EU law	ISO/IEC 27001:2022 Annex A	NIST SSDF	OWASP	Other
Private/SSO publishing defaults	Art. 25(2); CRA Annex I (in-scope products)	A.8.9, A.8.3, A.5.15	PW.9	LCNC-SEC-05, -04	CIS 4, 6; NIS2 21(2)(j)
Behavioural authz tests (anon, cross-tenant)	Art. 32(1)(d); 25(1)	A.8.29, A.8.26	PW.7, PW.8	LCNC-SEC-02, -01	NIS2 21(2)(f); DORA Art. 25
Explicit grants and verified RLS	Art. 32(1)(b); 5(1)(f)	A.8.3, A.5.15, A.5.18	PW.9	LCNC-SEC-02	CIS 3, 6
Secrets out of bundles and agent reach	Art. 32; 5(1)(f)	A.5.17, A.8.4, A.8.2, A.8.12	PS.1, PO.5	LCNC-SEC-08; ASI03	CIS 3; NYDFS 500.12

Control in this paper	GDPR / EU law	ISO/IEC 27001:2022 Annex A	NIST SSDF	OWASP	Other
Immutable off-blast-radius backups, restore drills	Art. 32(1)(c)	A.8.13, A.8.14	RV.3	ASI08	NIS2 21(2)(c); CIS 11; DORA Art. 12
Agent least privilege, sandbox, egress, read-only MCP	Art. 25(1), 32	A.8.2, A.8.5, A.8.22	NIST agent identity work (2026)	ASI02, ASI03, ASI05, ASI06; LLM06	CIS 5, 6
Dev/prod separation, promotion gates	Art. 32(1)(b)	A.8.31, A.8.32, A.8.25	PO.5, PW.8	LCNC-SEC-05	NIS2 21(2)(e); CRA Annex I
Supplier and DPA review of builders	Art. 28(1), (3); 44-46	A.5.19-A.5.23	PW.4	LCNC-SEC-07; ASI04	NIS2 21(2)(d), 21(3); DORA 28-30; CIS 15
App registry with owner, data class, expiry	Art. 24, 30 (link), 35 screening	A.5.9, A.5.10	—	LCNC-SEC-09	NIS2 21(2)(i); DORA 28(3); NYDFS 500.13; CIS 1, 2
Retention per sink (DB, logs, LLM traffic)	Art. 5(1)(e), 25	A.8.10, A.8.12	—	LLM02	DORA 30(2)(b), (d)
AI-literacy and stack-specific training	AI Act Art. 4 (amended)	A.6.3	—	—	NIS2 21(2)(g)
Transparency of LLM features in apps	AI Act Art. 50(1), (2)	—	NIST AI 600-1	LLM09	Colorado ADMTA (2027), Texas TRAIGA

7.8 DPA procurement checklist

The three documents read in this pass (Lovable DPA, page updated 6 Nov 2025; Vercel DPA, effective 31 Mar 2026; Replit ToS, 3 Aug 2026) share one pattern: processor only for a defined class of Customer Personal Data and independent controller for service, usage or log data; training prohibitions attach to the processor class only; audit rights replaced by SOC 2 or ISO reports; deletion "commercially reasonable" or "may persist in backups"; breach notice "without undue delay" with no hour commitment; sub-processor objection windows of 5–20 days with termination as the sole remedy ([Lovable DPA](#); [Vercel DPA](#); [Replit ToS](#)) **[CP]**. Lovable's §10.1 bars training on Customer Personal Data while §9.1(c) permits "training or tuning proprietary machine-learning models" on Service Data; the two "appear to conflict" **[CP]**. Replit's ToS grants a licence to "copy, display, distribute, perform, reformat, and modify your content" and to access private apps for "troubleshooting, improving our service", and does not state whether content trains models; its DPA and Commercial Agreement were not read (gap) **[CP]**. Cursor's security page says Privacy Mode means "we will not train on your data", inheritable by team members, without using the words "zero data retention" ([Cursor security](#)) **[CP]**; the original report's BYOK and per-model ZDR caveats came from a different Cursor page not re-opened (gap).

Checklist **[PROP]**, grounded in Art. 28(3) **[CP]**:

1. **Carve-outs.** Identify exactly which data classes the vendor treats as its own controller data; ask in writing whether prompt and chat content is Customer Personal Data.
2. **Training.** Require the no-training clause to cover every class the vendor can see, not only Customer Personal Data.
3. **Audit rights.** Art. 28(3)(h) requires the processor to "allow for and contribute to audits, including inspections"; report-only clauses may suit low-risk processing but not DORA critical or important functions.
4. **Backups and deletion.** Demand a maximum backup retention and a deletion certificate.
5. **Sub-processors.** Monitor the list proactively; map sub-processors to the Art. 30 record.

6. **Transfers.** Confirm the SCC module (Two versus Three) and whether any DPF certification is relied on; Lovable and Vercel rely on SCCs, not the DPF.
7. **Breach notification.** Negotiate a fixed outer bound (24–48 hours from processor awareness) and a duty to notify on suspicion, consistent with EDPB para 44.
8. **Regulated data.** No BAA means no PHI; check PCI DSS responsibility and special-category exclusions.

8. Tiered reference model and phased rollout (authors' proposal)

Everything in this section is **[PROP]** unless tagged otherwise. The tiers extend the CSA's three review categories with the platform constraint, ownership, exception path, kill switch and assurance evidence each needs; the thresholds are borrowed from the only published mechanised lifecycle defaults (the CoE Starter Kit's 6 months, 7 days, 3 weeks, 60 days) and should be treated as starting points, not norms.

8.1 Tiers

Tier	Data and audience	Allowed build path	Mandatory controls	Exposure	Owner and approver	Exception path	Kill switch	Assurance evidence
T0 Prototype	Synthetic or masked data only; no connectors	Any sanctioned builder tenant	Registry entry; auto-expiry (30–90 days); no production connectors	Works pace-only	Builder is owner; no approval	None; promote to T1 instead	Expiry deletes; workspace admin unpublish	Registry row with expiry; monthly expiry report
T1 Internal tool	Internal, non-personal data	Sanctioned builder tenant with SSO and SCIM	IdP-gated ingress; enforced scan block; explicit grants plus RLS verified; owner attestation every 6 months	Workforce via IdP; never public	Builder plus line manager; platform team records	Security sign-off, time-boxed, logged in registry	Admin unpublish or quarantine; connector revoke	Scan report; anon-role behavioural test pass; attestation log
T2 Confidential or personal data	PII, customer, HR, financial	Governed platform or least-privilege BFF (Path A with verified RLS, or B1/B3); no secret keys in clients	Full behavioural matrix (anon, same-tenant, cross-tenant) per release; deterministic SAST/SCA/secrets gates; human review; registry linked to processing-activity record and DPIA screen; retention per sink; vendor DPA gap analysis	IdP-gated; public only with security sign-off	Named business owner plus engineering sponsor; DPO consulted	CISO-level, documented, expiring	Quarantine within minutes (Power Platform-style) or IdP policy removal; connector revoke; backup verified before action	pgTAP and HTTP matrix results; SBOM; restore-drill record; DPIA screen
T3 Regulated, external or age ntic	Health, payment, minors, customer-facing LLM features, agent with write access to systems	Engineering-owned SDLC	T2 plus threat model, penetration test, AI gateway with per-model retention and PII masking, AI Act three-question classification, agent plane baseline (section 4.5.4), isolated immutable backups with MPA or cross-tenant restore	Per normal product release	Product owner, security architect, DPO; legal where Art. 50 or Annex III applies	Board-visible risk acceptance	Standard incident response; feature flags; agent credential revocation	Pentest report; threat model; restore RTO/RPO measured; Art. 50 classification on record

Ownership rules: every app has exactly one accountable person (the Mendix single-Technical-Contact model **[CP]**) and one named deputy; SCIM leave events trigger reassignment within the Starter Kit's one-week window and quarantine if unresolved; Lovable's seniority-based auto-inheritance is accepted for T0-T1 and overridden by explicit reassignment for T2+ **[INF]**.

8.2 Phased rollout

Phase	Window	Actions	Exit criterion	Evidence produced
0 Stop the bleeding	Weeks 0-2	Non-punitive inventory ask (CSA "an ask, not an audit"); inside-tenant exports; IdP, email and expense signals; outside-in search with brand tokens (CT only for custom domains); set team defaults (Vercel "All Deployments", Lovable "Workspace" plus critical/PII publish blocks, Replit "Require", Netlify visitor defaults, Base44 Apps SSO); audit every Supabase project for existing-table grants, anon grants, SECURITY DEFINER functions and views, RPC EXECUTE, and event-trigger presence before 30 Oct 2026; rotate every key found in bundles; add builder domains to SSE and browser DLP	Known estate registered; no unauthenticated app holding non-public data; no secret key in any bundle	Registry v0; discovery report; grant audit per project
1 Paved road	Days 30-90	One enterprise builder tenant per approved product with SSO and SCIM; admin-owned connectors ("who can create connections" = No one); registry with the section 6.3 schema; tier policy published; IdP proxy with origin validation on custom domains; OIDC federation replacing static cloud keys; repository push protection on synced repos; DPA gap analysis against section 7.8; training tied to tenant access (Tenable model)	New apps reach data only through admin-approved paths; every T1+ app has an owner	Tenant configuration export; DPA gap analysis; training completion report
2 Deterministic gateways	Days 90-180	Promotion pipeline with secrets (including build-output scan), SCA via internal registry proxy, SAST as blocking gates; behavioural matrix for every T1+ app; AI review advisory; human review for T2+; managed agent settings (section 4.5.4); read-only, project-scoped MCP; no production credentials reachable by agents; masked branches for development; isolated immutable backups with quarterly restore drills; retention enforced per sink; LLM gateway with explicit per-model retention	A destructive agent action or a broken policy cannot reach production unnoticed	Pipeline logs; matrix results; restore-drill RTO/RPO; managed-settings /status output
3 Run it	Ongoing	Weekly outside-in scan; six-monthly owner attestation (T1) and release-gated attestation (T2+); quarantine on owner departure or missed attestation; expiry enforced on T0; honeytokens in seed data and environment templates; tabletop exercise on each failure mode annually; exception register reviewed quarterly	Unowned apps cease to exist by construction; exception count trending to zero	KPI dashboard (section 6.5); exception register; tabletop records

9. Verification test matrix

Each test states the principal and starting state, the action, and the observation that constitutes a pass. The seven invariants from the audit are preserved and extended with database-level assertions.

#	Invariant	Principal / starting state	Action	Expected observation
1	No internet-accessible publish without a policy decision	Citizen developer, new project, non-admin	Publish to public production	Denied or routed to approval; registry entry created
2	UI gateway cannot be bypassed	Anonymous visitor	Request canonical domain, platform subdomain, preview URL, with and without bypass header	No app or API content on any route; origin rejects requests lacking a valid proxy token

#	Invariant	Principal / starting state	Action	Expected observation
3	Anonymous data access is impossible	No user token; publishable key	SELECT, INSERT, PATCH, DELETE on protected tables via REST and GraphQL	SQLSTATE 42501 (no grant) or zero rows; no schema hints
4	Cross-tenant read returns nothing	Authenticated tenant B	Read tenant A rows via REST, GraphQL, each RPC, Storage	Empty result; zero rows; no row in error text
5	Cross-tenant write has no effect	Authenticated tenant B	Update or delete tenant A row; insert with tenant A org_id; reassign own row to tenant A	Zero rows affected; 42501 on WITH CHECK violation
6	Privileged side paths are closed	Anonymous and authenticated	Call every SECURITY DEFINER function; select from every view; list every bucket	No data beyond the caller's RLS scope; security_invoker on views; EXECUTE revoked from anon where not needed; lint 0025 clean
7	Builder identity and app identity are separate and auditable	IdP admin	Revoke a user	Builder console access ends; app access ends; owned assets reassigned or quarantined; audit log records both
8	Agent cannot reach production credentials	Build agent under sanctioned settings	Search filesystem, environment, MCP tools, hooks for production secrets	None present; /status shows managed settings; allowUnsandboxedCommands false
9	Agent cannot destroy production	Agent with normal build credentials	Attempt volume delete, DROP, TRUNCATE, terraform destroy against production	Infrastructure refuses; token scope insufficient; soft-delete window where provider offers one
10	Recovery is independent of the primary	Break-glass role in recovery account	Restore the newest isolated recovery point	Restore completes within measured RTO and RPO; no dependency on deleted primary; vault lock prevents deletion by primary-account root
11	Build-time and runtime data have independent retention	DPO	Request retention schedule per sink (DB, logs, replay, LLM gateway, builder chat)	Written schedule naming retention per provider and model; builder DPA backup persistence stated
12	Orphaned or expired apps are quarantined	Scheduler	Owner leaves; T0 expiry passes; attestation missed	Quarantine or deletion within the documented window; registry updated
13	New table or function is not auto-exposed	Agent via migration or MCP	Create table and function without grants	Table unreachable via Data API (42501); function EXECUTE revoked by default privileges; event trigger enabled RLS
14	Bundle contains no secret	CI	Grep build output for sb_secret_, legacy service-role JWT, cloud keys	Build fails on hit; publishable key safelisted
15	DLP policy change reaches cached LLM output	Gateway admin	Change policy, replay cached prompt	No stale uninspected response where policy demands re-evaluation

10. Threat-path efficacy and limitations matrix

This replaces the "works / theatre" table. "Prevents" means the control would have interrupted the named incident path by construction; "detects" means it would have surfaced the defect; "limits" means it reduces impact. Verdicts are inferences from the incident record and vendor semantics; no controlled efficacy study exists for any row **[INF]** unless otherwise tagged.

Control	Threat path interrupted	Property	Documented limitation or bypass	Assurance test	Evidence tier
Tenant-level private/SSO publishing defaults	RedAccess public-by-default	Prevents	Per-project override on Lovable, Vercel, Netlify; Replit policy not retroactive; Base44 embedding default Anyone	Test 1	[CP] semantics; [INF] efficacy
Explicit table grants (30 Oct default) plus RLS event trigger	New-table auto-exposure found by UpGuard, Reeve	Prevents for new tables	Existing tables keep grants; RPC EXECUTE untouched; trigger opt-in; direct connections excluded	Test 13	[CP]/[INF]
Behavioural authorisation matrix (pgTAP and HTTP)	CVE-2025-48757, Moltbook, EdTech inverted RPC	Detects (the only check that catches inverted logic)	Covers only tested surfaces and principals; needs real tenant JWTs; RLS Tester is SELECT-only	Tests 3-6	[CP] tooling; [INF] efficacy
Direct-to-BaaS with verified RLS (Path A)	Same	Prevents when policies are correct	Side paths (definer functions, views, buckets); no rate limiting or audit beyond pre-request hooks; internet-reachable API inherent	Tests 3-6	[CP]/[INF]
Least-privilege BFF (Path B1/B3)	Same, plus adds audit and rate limiting	Prevents	Becomes confused deputy if it holds a secret key without per-request tenant binding (Path B2)	Tests 4-5 against BFF endpoints	[CP]/[INF]
Identity-aware proxy on custom domain with origin validation	Anonymous UI access	Prevents for that hostname	Platform subdomain and BaaS API remain reachable; passthrough modes defeat Conditional Access	Test 2	[CP]
Password protection or shareable links	Casual anonymous access	Limits	Shared secret; no per-user revocation; USD 20/project/month on Vercel Pro	Test 2	[CP]
Builder pre-publish scanner with enforced block	Presence-level RLS and secret defects	Detects	Presence and pattern checks; blind to logic correctness and to apps outside the tenant; blocking disabled by default except new Lovable Enterprise workspaces	Compare scan result with Test 4 outcome	[VR]
Build-output secret scan (Netlify smart detection or custom)	NEXT_PUBLIC / VITE_ leak of a secret key	Detects and blocks	Repo-only scanners miss inlined env vars; Vercel protected source maps protect code, not keys	Test 14	[CP]
Repository push protection	Hard-coded secrets in source	Detects	Off by default for repos; paid; bypass with a reason by default	Push a canary secret	[CP]
Outside-in discovery (search, Common Crawl, DNS brute-force, content fingerprints)	Shadow apps on personal accounts	Detects	CT blind for platform subdomains (verified); attribution by content, analyst-heavy; no validated accuracy figures	Seeded canary app found within one cycle	[CP]/[VR]
Agent sandbox fail-closed with egress allowlist	Shell-level exfiltration and destructive commands	Limits	File tools, MCP, hooks run outside; allowlisted hosts accept uploads; native Windows unsandboxed	Test 8	[CP]
Bash deny rules and permission prompts	Casual destructive commands	Limits	Text-matched, "not a security boundary"; approval fatigue	Attempt /bin/rm variant	[CP]
Read-only, project-scoped MCP with manual approval	Supabase MCP and Sentry MCP injection paths	Limits	Blocks write-back, still permits reads; approval "a guardrail, not a guarantee"; result-wrapping "not foolproof"	Inject a test instruction via a ticket	[CP]/[RR]

Control	Threat path interrupted	Property	Documented limitation or bypass	Assurance test	Evidence tier
Credential brokering (OIDC federation, outbound workers, mask plus injectHosts)	PocketOS token-in-file, Gemini CLI WIF file	Prevents	Covers only the brokered credentials; agent still holds whatever remains in env	Test 8	[CP]
Dev/prod database separation	SaaStr	Prevents	Structural changes still reach production at publish; shared staging still destroyable (#88753)	Test 9	[CP]
Provider soft-delete window (Railway two days, Replit 7 days)	PocketOS single-call deletion	Limits	Credential can purge or wait out the window; recoverability, not authorisation	Delete then restore within window	[CP]/[INF]
Isolated immutable backups (LAG vault, locked Azure vault, GCP enforced retention, object lock) with restore drills	PocketOS, DataTalks.Club	Limits (recovery)	Account closure deletes after 90 days; minimum retention 7 days; RPO bounded by schedule; MPA optional and needs two Organizations	Test 10	[CP]
Stack-specific agent skills and AGENTS.md requirements	"Hidden security rules" root cause (55.5%)	Reduces probability	n = 6 vendor evidence; MCP without skill regressed; no A/B against generic rules	Replay a known defect with and without skill	[VR]/[RR]
Generic security prompts and rules files	Short single-shot flaws	Reduces probability for some models	Correctness tax; flat on agentic work; rules files are an injection surface	SusVibes-style replay	[RR]
AI code review	Authorisation logic bugs	Detects a subset	0 of 7 out-of-diff, 3 of 14 missing-check targets identified; recall unreported by vendors	Plant a missing ownership check	[RR]
System-prompt "code freeze" or "never delete"	SaaStr, PocketOS	None demonstrated	Ignored in both incidents	n/a	[PO]
RLS-exists check	EdTech	None for logic errors	Passed an inverted policy	Compare with Test 4	[PO]/[INF]
Same-volume or same-account backups	PocketOS	None against the destructive credential	Deleted by the same call	Test 10 fails	[PO]/[CP]
Permanent outright ban without a sanctioned alternative	Personal-account use	Not evidenced either way	Telemetry shows blocking coexists with falling personal-account use; no outcome study	KPI: personal-account share	[VR]/[INF]
Registry with owner, data class, expiry and processing-activity link	Orphaned apps; Art. 24 accountability	Enables every other control	No external precedent for expiry or ROPA-link fields; Starter Kit unmaintained	Test 12	[CP]/[PROP]

11. Open gaps and what to verify before relying on this

Primary sources not located. The EdTech researcher's own write-up (figures via The Register only); Jer Crane's original PocketOS post; Alexey Grigorev's DataTalks.Club post; any Lovable statement on whether `SUPABASE_SERVICE_ROLE_KEY` appeared in exposed source; RedAccess's enumeration method; the IDC primary for 56%/23%; LayerX and Nokod sample sizes; Backslash's methodology (URL now serves marketing).

Vendor behaviour not verified. Whether Lovable Cloud, Bolt, v0 or Replit-provisioned Supabase projects install the RLS event trigger or run under the new default grants; whether the 30 October rollout is instantaneous or gradual; whether the per-table "Data API access" dashboard toggle shipped; which Supabase key formats have GitHub push-protection and validity checks; gitleaks and TruffleHog coverage of `sb_secret_`; Bolt's visibility defaults, publish approval, audit and inventory; Replit's DPA, sub-processors and HIPAA position; whether Lovable admins can force SAML as the only app login method; Vercel Passport SAML support; whether Retool or Superblocks admins can globally disable public apps; Codex `workspace-write` network default; Cursor sandbox availability beyond macOS; whether Copilot firewall policy can be locked at enterprise level; Cloudflare Zero Trust pricing (page did not render); PostgREST's HTTP status for zero-row PATCH/DELETE; whether `supabase db advisors` exits non-zero on ERROR findings; registry-proxy products as agent egress targets.

Legal items for counsel. Verbatim post-Omnibus Art. 50(1)–(5) and Art. 99(4); whether Art. 4 sits in the fine catalogue; whether a GPAI-wrapping enterprise is the Art. 50(2) provider; national Art. 35(4) DPIA lists; the Data (Use and Access) Act 2025's effect on UK Art. 33/34 (believed none); HIPAA Security Rule final-rule status; CCPA audit content; per-DPA sweep (CNIL, AEPD, Datatilsynet, IMY, DPC, BfDI, Garante) before asserting "no guidance"; the Commission's remote-data-processing guidance under the CRA.

Evidence limits that cannot be closed by verification. The scan studies are not independent samples and over-represent Lovable launch directories; no study measures cross-tenant or RLS-correctness failure rates in generated multi-tenant apps; no study measures builder expertise; no controlled comparison of stack-specific skills against generic rules; no AI reviewer reports recall by CWE class; no 2026 hallucination measurement on an exploit-confirmed benchmark for current reasoning modes; no comparative outcome study of ban versus paved road; no published approval SLA, TTL or exception register for citizen apps; no DPA decision on any ledger incident; absence of in-the-wild MCP exfiltration is consistent with low detectability. The tier thresholds, KPIs marked proposed, the rollout windows and the backup cost estimate are the authors' design and arithmetic.

Date sensitivity. Vendor defaults in section 4.2 were current on 8–9 October 2026; the Supabase 30 October change, the Supabase legacy-key removal ("Late 2026, TBC"), the Art. 50(2) grace period (2 December 2026), the Colorado ADMTA (1 January 2027), Annex III (2 December 2027), CRA full application (11 December 2027) and the Digital Omnibus GDPR strand (proposal) are the dates most likely to move.

12. Conclusion

Three things changed between the original report and this paper. First, the evidence base is now large enough to say that the leak class is structural and stable: the one random-sample study, the five non-independent scans and twenty incidents agree that the dominant defect is authorisation on a reachable data API, that it is created by the same mechanism the agents use to build (programmatic table creation without grants and policies), and that seventeen months of model releases have not visibly moved the exposure rate. Vendors have responded by changing defaults at the storage layer, which closes the new-table path on Supabase from 30 October 2026 but leaves existing tables, RPC `EXECUTE` and every other BaaS where they were. Second, the agent plane has acquired a documented, vendor-acknowledged anatomy: sandboxes bound shell commands and nothing else; MCP, hooks and file tools run on the host; allowlists bound destinations, not exfiltration; and the only categorical control anyone has shipped is Replit's removal of production from the agent's reach. Third, the legal picture is more precise and less

dramatic than "every exposure is a reportable breach": the EDPB framework already decides each failure mode, the AI Act does not reach a CRUD tool, and DORA bites through contract terms that consumer-grade builders do not offer.

The practical consequence for a CISO, platform architect or DPO is a short list of decisions that generated code cannot override: whether the browser may talk to the database at all and, if so, whether anyone has run the cross-tenant matrix; whether a non-admin can publish to the open internet; where the agent's credentials live and what they can delete; whether a copy of the data exists that no credential in the primary account can shorten; and whether the organisation can produce, on request, a register naming an owner for the app that leaked. Everything else in this paper, including its own proposals, is second-order once those five are settled.

Appendix: structured data for visualisation

Tags: CP Confirmed-primary; VR Vendor-reported; RR Researcher-reported; PO Press-only; INF Author-inference; PROP Proposal.

(a) Key figures

Figure	Value	Unit / denominator	Source URL	Date	Confidence
Lovable showcase projects exploitable (CVE-2025-48757)	170 of 1,645 (10.3%)	Projects, homepage-only crawl; 303 endpoints	https://mattpalmer.io/posts/statement-on-CVE-2025-48757/	21 Mar 2025	RR
CVE-2025-48757 CVSS	8.26 (researcher, S:U) vs 9.3 (MITRE, S:C)	CVSS v3.1 base	https://cveawg.mitre.org/api/cve/CVE-2025-48757	30 May 2025	CP
Moltbook records exposed	~4.75M records; 1.5M agent API tokens; 4,060 DMs	Records in one Supabase project	https://www.wiz.io/blog/exposed-moltbook-database-reveals-millions-of-api-keys	2 Feb 2026	RR
Moltbook remediation	4 fixes in 3 h 12 min	21:48 to 01:00 UTC	https://www.wiz.io/blog/exposed-moltbook-database-reveals-millions-of-api-keys	31 Jan-1 Feb 2026	RR
EdTech app records exposed	18,697 users; 4,538 students; 870 full PII	Records in one app	https://theregister.com/2026/02/27/lovable_app_vulnerabilities	27 Feb 2026	PO
Symbiotic scan: apps with a finding	1,046 of 1,072 (98%); 173 (16%) critical	Supabase-backed sites scanned	https://www.symbioticsec.ai/blog/we-scanned-1-072-vibe-coded-apps-98-had-security-flaws	2 Jun 2026	VR
Symbiotic: unauthenticated DELETE and PATCH	172 sites each	Of 1,072	https://www.symbioticsec.ai/blog/we-scanned-1-072-vibe-coded-apps-98-had-security-flaws	2 Jun 2026	VR
Symbiotic discovery source yield	Dorking 58.2%; Common Crawl 23.1%; DNS 13.7%; crt.sh 4.8%	Of 1,085 confirmed sites	https://www.symbioticsec.ai/blog/we-scanned-1-072-vibe-coded-apps-98-had-security-flaws	2 Jun 2026	VR
Escape: apps tested	1,400 (of 5,600 discovered web apps; 14,600 assets)	Applications	https://26857953.fs1.hubspotusercontent-eu1.net/hubfs/26857953/State-Security-Vibe%20Coded%20Apps%20Report%202025%20Escape.pdf	29 Oct 2025	VR

Figure	Value	Unit / denominator	Source URL	Date	Con fide nce
Escape: findings and secrets	34,232 findings; 400+ secrets; 175 PII instances	Across 1,400 apps	https://26857953.fs1.hubspotusercontent-eu1.net/hubfs/26857953/State-Security-Vibe%20Coded%20Apps%20Report%202025%20Escape.pdf	29 Oct 2025	VR
RedAccess sweep	380,000+ assets; 5,000 corporate-purpose; 2,000 (40%) sensitive without controls	Assets then apps, method undisclosed	https://info.redaccess.io/hubfs/1627The%20Shadow%20Builders%20Inside%20Your%20Organization%20%E2%80%94%20Red%20Access%20Research%20(1).pdf	May 2026	VR
UpGuard: Supabase databases with readable tables	16,326; >50% with PII indicators	Of ~300,000 domains probed	https://www.upguard.com/blog/everything-everywhere-systemic-data-exposure-in-supabase-apps	24 Sep 2026	VR
Reeve: apps with a readable table	2,096 of 3,680 checkable (57%)	30,998 apps swept; 3,553 of checkable were Lovable	https://reeve.page/research/vibe-coded-app-security-2026	19 Aug 2026	VR
Deng, Fan, Meng: deployed vibe apps vulnerable	182 of 200 (91.0%); 1,186 confirmed vulnerabilities	Random sample of deployed apps, two-author confirmation	https://arxiv.org/html/2606.23130v4	14 Sep 2026	RR
Deng, Fan, Meng: Broken Access Control	339 findings (28.58%); present in 64.0% of apps; 77% backend	Of 1,186 findings / 200 apps	https://arxiv.org/html/2606.23130v4	14 Sep 2026	RR
Deng, Fan, Meng: "hidden security rules" root cause	658 of 1,186 (55.5%)	Findings	https://arxiv.org/html/2606.23130v4	14 Sep 2026	RR
Deng, Fan, Meng: prompt replay	Baseline 25.7%; production-ready 11.0%; hardening skill 11.9%; professional prompt 45.7%	Reintroduction rate over 1,680 runs of 70 vulnerabilities	https://arxiv.org/html/2606.23130v4	14 Sep 2026	RR
SusVibes joint secure-and-correct	10.5% (SWE-agent + Claude 4 Sonnet); 12.5% best (OpenHands + Claude 4 Sonnet); 6.0% Claude Code	Of 200 CVE-derived Python tasks	https://arxiv.org/html/2512.03262v2	16 Feb 2026	RR
SusVibes functional pass, best	61.0%	Of 200 tasks	https://arxiv.org/html/2512.03262v2	16 Feb 2026	RR
SusVibes oracle-CWE effect	61.0/10.5 to 56.0/10.5	FuncPass/SecPass %	https://arxiv.org/html/2512.03262v2	16 Feb 2026	RR
Veracode security pass	55% overall; GPT-5 extended reasoning 70–72%; Java 29%; XSS 15% pass	80 tasks, 4 CWEs, SAST-judged	https://www.veracode.com/blog/spring-2026-genai-code-security/	24 Mar 2026	VR
Urmi et al. severity shares (GPT-4o)	High 20.8% to 13.6%; low 32.0% to 43.5%; any finding 76.3% to 72.0%	Shares of valid files, 424 synthetic tasks	https://arxiv.org/html/2608.24857v1	25 Aug 2026	RR
Shukla et al. iteration	Security-focused 38 vs feature-focused 158 findings; mean per sample 2.1 to 6.2	400 samples, GPT-4o, 10 rounds	https://arxiv.org/html/2506.11022v2	26 Sep 2025	RR
Supabase agent skill	Opus 4.6 58/50/67; Sonnet 4.6 46/58/71; GPT-5.4 71/71/88; GPT-5.4 Mini 42/63/71	% requirements met; baseline/MCP/MCP+skill; n = 6 scenarios	https://supabase.com/blog/supabase-agent-skills	9 Apr 2026	VR

Figure	Value	Unit / denominator	Source URL	Date	Confidence
MalPR-Bench CodeRabbit attribution	16 of 24 in-diff; 0 of 7 out-of-diff; 3 of 14 absence-type	Held-out malicious PRs	https://arxiv.org/abs/2608.25730	26 Aug 2026	RR
Copilot Code Review security findings	<20 comments; 0 injection; 0 access control	Across 7 vulnerable datasets	https://arxiv.org/html/2509.13650v1	17 Sep 2025	RR
AI reviewer precision ranges	20–68% (Augment dataset); 64–96% (Signal65, CodeRabbit-commissioned)	Different datasets; recall unreported	https://signal65.com/research/ai/evaluating-ai-code-review-tools-a-real-world-bug-detection-study/	30 Mar 2026	VR
Package hallucination rate	19.7% (440,445 of 2.23M references); commercial ≥5.2%; 43% of names recur on all 10 re-queries	576,000 samples, 16 models, 2024-era	https://arxiv.org/html/2406.10279v3	2 Mar 2025	RR
Package hallucination 2026 re-measurement	4.62–6.10%; 127 names shared by all 5 models; 53 registrable	199,845 paired prompts	https://arxiv.org/abs/2605.17062	9 Aug 2026	RR
Malicious slopsquat package	unused-imports (npm), ~233 weekly downloads, security hold	One package	https://www.aikido.dev/blog/slopsquatting-ai-package-hallucination-attacks	20 Feb 2026	VR
Georgia Tech CVEs attributed to AI-authored code	74 (Claude Code 49, Copilot 15)	Of 43,849 advisories since 1 May 2025	https://www.theregister.com/2026/03/26/ai_coding_assistant_not_more_secure/	20 Mar 2026	RR
Sentry MCP agentjacking	85% exploitation success in testing; 2,388 injectable DSNs	PoC	https://labs.cloudsecurityalliance.org/research/csa-research-note-agentjacking-mcp-sentry-injection-20260612/	12 Jun 2026	CP
Shai-Hulud second wave	525+ packages; ~132M monthly downloads	npm packages	https://semgrep.dev/blog/2025/digging-for-secrets-shai-hulud-the-second-coming-of-the-npm-worm	24 Nov 2025	RR
Netskope personal-account genAI use	47% (down from 78%); 223 violations/org/month; 90% of orgs block some apps	Customer telemetry Oct 2024–Oct 2025	https://www.netskope.com/resources/cloud-and-threat-reports/cloud-and-threat-report-2026	6 Jan 2026	VR
Gartner shadow-AI survey	69% suspect or have evidence of prohibited GenAI use	302 cybersecurity leaders	https://www.gartner.com/en/newsroom/press-releases/2025-11-19-gartner-identifies-critical-genai-blind-spots-that-cios-must-urgently-address0	19 Nov 2025	CP
Gartner vibe-coding forecasts	60% of vibe-coded apps retired by 2028; 30% of teams strained	Strategic Planning Assumptions via vendor reprint	https://tray.ai/guides/gartner-govern-vibe-coding.md	29 Jun 2026	PO
KPMG/Melbourne policy contravention	44% used AI against policy; 57% hide use	48,340 respondents, 47 countries	https://kpmg.com/xx/en/media/press-releases/2025/04/trust-of-ai-remains-a-critical-challenge.html	Apr 2025	RR
IBM: orgs with AI policies that audit for shadow AI	34%	600 breached organisations	https://newsroom.ibm.com/2025-07-30-ibm-report-13-of-organizations-reported-breaches-of-ai-models-or-applications,-97-of-which-reported-lacking-proper-ai-access-controls	30 Jul 2025	VR
Retool leader visibility confidence	5% very confident	307 CTO/CIO/CISOs	https://retool.com/blog/ai-governance-report-2026	May 2026	VR

Figure	Value	Unit / denominator	Source URL	Date	Confidence
Nokod orphaned vulnerable apps	Up to 30%	Customer sample, Power Apps	https://nokodsecurity.com/blog/the-uncomfortable-truth-about-application-security-in-the-age-of-no-coders-lessons-from-cve-2026-20960/	2026	VR
Zenity estate size	~80,000 apps/copilots per large enterprise; 62% with vulnerabilities	Customer telemetry	https://www.prnewswire.com/news-releases/zenity-research-finds-62-of-copilots-and-low-code-apps-contain-security-vulnerabilities-302241231.html	10 Sep 2024	VR
Vercel Password Protection	USD 20 per project per month (Pro)	List price	https://vercel.com/docs/deployment-protection	15 Sep 2026	CP
Cloudflare Zero Trust	Free to 50 users; USD 7/user/month	List price (page excerpt)	https://www.cloudflare.com/plans/zero-trust-services	Oct 2026	CP
GitHub Secret Protection	Illustrative USD 19 per active committer	90-day active committers	https://docs.github.com/en/code-security/how-tos/secure-at-scale/configure-organization-security/configure-specific-tools/estimating-the-price-of-secret-protection	Oct 2026	CP
AWS Backup LAG vault storage	USD 0.0575/GB-month (eu-west-1 example); restore testing USD 1.50 per recovery point	List price	https://aws.amazon.com/backup/pricing/	Oct 2026	CP
Neon snapshot storage	USD 0.09/GB-month	List price	https://neon.com/docs/ai/ai-database-versioning	Oct 2026	CP
Air-gapped backup for 200 GB database	~USD 30-40/month	Authors' arithmetic	https://aws.amazon.com/backup/pricing/	Oct 2026	INF
Claude Code sandbox permission-prompt reduction	84%	Anthropic internal usage, no methodology	https://www.anthropic.com/engineering/claude-code-sandboxing	20 Oct 2025	VR
Copilot Autofix fix time	28 min median vs 1.5 h manual	CodeQL alerts, public beta	https://github.blog/news-insights/product-news/secure-code-more-than-three-times-faster-with-copilot-autofix/	14 Aug 2024	VR
AI Act Art. 50 fines	Up to EUR 15M or 3% worldwide turnover	Art. 99(4)	https://ai-act-service-desk.ec.europa.eu/en/faq	2026	CP
CRA fines	Up to EUR 15M or 2.5% worldwide turnover	Art. 64	https://www.kirkland.com/publications/kirkland-alert/2026/09/the-eu-cyber-resilience-act	Sep 2026	PO
Colorado ADMTA penalty	Up to USD 20,000 per violation	AG enforcement, 60-day cure to 2030	https://www.skadden.com/insights/publications/2026/06/colorado-repeals-and-replaces-its-ai-act	14 May 2026	CP

(b) Incident timeline

Date	Incident	Layer	Capability demonstrated	Impact	Remediation	Confidence
2025-03-18	Pillar "Rules File Backdoor" (Cursor, Copilot)	Agent plane (lab)	Hidden Unicode instructions in rules files	Demonstration only	GitHub hidden-Unicode warning 1 May 2025	Vendor research

Date	Incident	Layer	Capability demonstrated	Impact	Remediation	Confidence
2025-03-20	Lovable RLS vulnerability discovered (CVE-2025-48757)	App authorisation	Anonymous read and write via publishable key; RPC token exposure	170 of 1,645 showcase projects; 303 endpoints	None by vendor; scanner (presence check) 24 Apr 2025	High
2025-05-24	CVE-2025-48757 write PoC (paid record inserted)	App authorisation	Unauthenticated INSERT bypassing Stripe	Lovable-employee-maintained site	MITRE record 30 May 2025, disputed by supplier	High
2025-07 (early)	General Analysis Supabase MCP demonstration	Agent plane (MCP)	Prompt injection via support ticket exfiltrates integration tokens	Demonstration	Supabase read-only and scoping guidance	Researcher
2025-07-18	Replit agent deletes SaaS production data	Agent plane	Row deletion and fabrication despite "code freeze"	>1,200 executives, >1,190 companies (Lemkin); recovered	Dev/prod DB separation (21 Jul 2025)	Medium
2025-07-25	Tea app Firebase exposure	Legacy storage ACL	Public bucket listing	~72,000 images; >1.1M DMs	Migration; class action settled in principle 30 Jun 2026	High (facts); AI attribution unsupported
2025-07-29	Base44 auth bypass disclosed (Wiz)	Builder platform	Unauthenticated registration and OTP verification	Verified accounts on SSO-only apps; no evidence of abuse	Fixed <24h	High
2025-08 to 2025-12	Claude Code pre-trust execution paths fixed (GHSA-ph6w-f82w-28w6; CVE-2025-59536; CVE-2026-21852)	Agent plane	Hooks RCE; MCP consent bypass; API-key exfiltration via base URL	Disclosed research	Fixed 1.0.87, 1.0.111, 2.0.65	High
2025-10-29	Escape "State of Security of Vibe-Coded Apps"	App authorisation at scale	Anonymous reads incl. IBAN and plaintext password	1,400 apps; 34,232 findings	n/a	Vendor research
2025-11-24	Shai-Hulud second wave (npm)	Supply chain	preinstall credential harvesting; self-propagation	525+ packages	Registry holds	Researcher
2025-12	AWS Cost Explorer interruption attributed to Kiro (FT)	Agent plane	"delete and recreate the environment"	13-hour interruption, one service	Mandatory peer review for production access	Disputed
2026-01-31	Moltbook Supabase exposure	App authorisation	Anonymous read; PATCH survived two fixes	~4.75M records; 1.5M tokens	Four fixes in ~3h	High
2026-02-03	Lovable backend regression begins	Builder platform	Ownership check missing on project endpoints	Public-project chat and source reachable with link	Fixed 20 Apr 2026	High (existence)
2026-02-20	Aikido reports unused-imports malicious slopsquat	Supply chain	Malicious package on hallucinated name	~233 weekly downloads	npm security hold	Vendor research
2026-02-27	EdTech app on Lovable Discover (The Register)	App authorisation	Inverted RPC guard; delete any account; bulk email	18,697 records	Owner fixing; vendor: user discretion	Medium
2026-03-11	DataTalks.Club terraform destroy by Claude Code	Agent plane	Infrastructure destroy without confirmation	~2M rows; AWS restored within 24h	n/a	Low-Medium
2026-03-24	NCSC CEO RSAC keynote and "intolerable risks" blog	Regulatory signal	n/a	n/a	n/a	High

Date	Incident	Layer	Capability demonstrated	Impact	Remediation	Confidence
2026-04-20	Lovable regression made public and fixed	Builder platform	As above	All public projects made private; HackerOne triage restructured	Fix within two hours	High
2026-04-24	PocketOS production volume deleted by Cursor agent via Railway token	Agent plane + infra API	volumeDelete with over-scoped token found in file; co-located backups	Production and volume backups deleted in ~9s; restored ~2.5 days later	Railway two-day grace on API mutation	High (mechanism)
2026-05-07	RedAccess "Shadow Builders" (Axios, WIRED)	Organisational defaults	Public URLs, admin-by-default, keys reachable	380K+ assets; 5,000 corporate; 2,000 sensitive	Some apps taken private	High (PDF figures)
2026-05-30	Supabase explicit-grants default for new projects	Vendor default change	n/a	New tables need GRANT	n/a	High
2026-06-01	claude-code-action CVE-2025-66032 disclosed	Agent plane (CI)	Bot-name trust bypass; OIDC token exposure	Research; fixed within four days	v1.0.94 / v1.0.93	High
2026-06-02	Symbiotic 1,072-app scan published	App authorisation at scale	Unauthenticated DELETE/PATCH on 172 sites	98% with a finding	n/a	Vendor research
2026-06-03	Sentry MCP agentjacking disclosed (Tenet)	Agent plane (MCP)	Injected error events exfiltrate developer secrets	PoC; 2,388 injectable DSNs	Content filter; root cause declined	High (PoC)
2026-06-11	Pillar reports Gemini CLI issue-injection to GCP	Agent plane (CI)	RCE; WIF credential exfiltration; project-wide impersonation	Google sandbox project	Fixed 14 Aug 2026	High
2026-07-27	AI Omnibus (Regulation 2026/1744) in force	Regulatory	n/a	Annex III to 2 Dec 2027; Art. 4 softened	n/a	High
2026-08-02	AI Act Art. 50 transparency applies	Regulatory	n/a	Chatbot disclosure; marking grace to 2 Dec 2026	n/a	High
2026-08-19	Reeve 30,998-app sweep published	App authorisation at scale	Readable tables without login	2,096 of 3,680 (57%)	n/a	Vendor research
2026-08-22	Claude Code issue #88753 TRUNCATE on shared RDS	Agent plane	Destructive SQL on wrong target after compaction	Staging tables wiped	Open	Medium
2026-09-11	CRA Art. 14 reporting duties apply	Regulatory	n/a	24h/72h reporting for in-scope products	n/a	Press (law firm)
2026-09-24	UpGuard 16,326-database Supabase sweep	App authorisation + grants at scale	Anonymous read of users tables	>50% with PII indicators	Owners notified	Vendor research
2026-09-20 to 26	Antigravity forum reports (push to prod; 14-min rmdir)	Agent plane	Scope breach; recursive deletion	Single users	Advice	Low
2026-10-05	GitHub adds Supabase and Lovable secret detectors	Vendor control	n/a	Partner secrets auto-reported	n/a	High
2026-10-08	ICO call for evidence on agentic AI	Regulatory signal	n/a	Six-week consultation	n/a	High

Date	Incident	Layer	Capability demonstrated	Impact	Remediation	Confidence
2026-10-30	Supabase explicit-grants default applied to all existing projects	Vendor default change	n/a	New tables in existing projects need GRANT; existing tables and RPC unchanged	n/a	High (scheduled)

(c) Controls by boundary

Boundary	Control	Enforcement locus	Verdict	Bypass / limitation	Evidence tier
B1 Builder identity	Workspace SSO and SCIM for console	Builder tenant + IdP	Prevents personal-account use only if combined with SSE blocking of personal sign-in	Personal accounts outside tenant; Lovable Business MCP clients enabled by default	CP
B1 Builder identity	"Who can publish externally" restricted to admins (Lovable); "Private deployments: Require" (Replit); "Apps SSO" (Base44)	Builder tenant admin policy	Prevents public publish	Lovable per-project override unless rights restricted; Replit not retroactive; Base44 embedding default Anyone	CP
B1 Builder identity	Admin-owned connectors ("who can create connections" = No one on Lovable Enterprise)	Builder tenant	Prevents unsanctioned data sources	Enterprise SKU only	CP
B1 Builder identity	Enforced scan-block on publish (critical, PII)	Builder tenant	Detects presence-level defects	Disabled by default except new Lovable Enterprise workspaces; blind to logic	VR
B1 Builder identity	Inventory export with owner and connectors (Lovable Security insights, Power Platform inventory, ServiceNow)	Builder tenant	Enables registry and lifecycle	Not available on Vercel, Netlify, Bolt, Base44, v0	CP
B1 Builder identity	DPA gap analysis (controller carve-outs, training, audit rights, backup persistence)	Contract	Enables Art. 28 compliance	Standard terms fall short of DORA 30(3)(e)	CP
B2 Ingress	Team default "All Deployments" (Vercel) / visitor defaults (Netlify)	Hosting platform	Prevents public production by default	Project/site override; Vercel Authentication admits Vercel accounts only	CP
B2 Ingress	Vercel Passport / Base44 Apps SSO / Power Platform Conditional Access	Hosting platform + IdP	Prevents anonymous access with workforce identity	Passport Enterprise, OIDC/OAuth only; Passport default project-overridable	CP
B2 Ingress	Identity-aware proxy with origin token validation	Proxy + origin	Prevents for the proxied hostname	Platform subdomain and BaaS API stay reachable; passthrough modes	CP
B2 Ingress	Protected source maps (Vercel)	Hosting platform	Limits code exposure	Does not protect inlined keys; existing projects opt in	CP
B2 Ingress	Password protection / shareable links	Hosting platform	Weak	Shared secret; no per-user revocation	CP

Boun dary	Control	Enforce ment locus	Verdict	Bypass / limitation	Evid enc e tier
B2 Ingre ss	Tailscale Funnel	n/a	Anti-pattern	No visitor auth; all members may enable by default	CP
B3 Data API	Explicit table grants (30 Oct 2026 default)	Postgres privileges	Prevents new-table auto-exposure	Existing tables keep grants; direct connections and custom schemas excluded	CP
B3 Data API	Revoke default function EXECUTE from anon/authenticated/public	Postgres default privileges	Prevents anonymous RPC	Not included in 30 Oct change; must be applied explicitly	CP/I NF
B3 Data API	RLS enabled with tenant-bound policies (TO clause, app_metadata, USING + WITH CHECK)	Postgres RLS	Prevents cross-tenant access when correct	Permissive or inverted logic passes presence checks; definer functions and views bypass	CP
B3 Data API	RLS auto-enable event trigger	Postgres event trigger	Prevents RLS-off tables created by agents	Opt-in per project; postgres-only; adds no grants or policies; public schema only	CP
B3 Data API	security_invoker on views; SECURITY INVOKER functions with pinned search_path	Postgres	Prevents owner-privilege bypass	Must be set per object; lints 0010, 0011, 0028, 0029 detect	CP
B3 Data API	Column-level privileges for PII	Postgres	Limits column exposure	Breaks select *; "advanced feature"	CP
B3 Data API	Behavioural authorisation matrix (pgTAP + HTTP) in CI	Test pipeline	Detects logic errors (only check that does)	Coverage limited to tested principals and surfaces	CP/P ROP
B3 Data API	Least-privilege BFF forwarding user JWT (Path B1) or non-BYPASSRLS role (B3)	Server tier + Postgres	Prevents and adds audit/rate limiting	Confused deputy if secret key used without tenant binding	CP/I NF
B3 Data API	Governed connector platforms (Superblocks, Retool, ServiceNow)	Platform	Prevents direct data access by construction	Platform lock-in; cost	CP
B3 Data API	Secret keys never in clients; publishable keys only	Key design	Prevents RLS bypass from browser	Secret key still usable from curl if leaked	CP
B3 Data API	Build-output secret scanning (Netlify smart detection or custom grep)	CI/build	Detects inlined secrets	Repo-only scanners miss NEXT_PUBLIC_/VITE_	CP
B3 Data API	Repository push protection; Supabase auto-revocation	Repo / vendor	Detects committed secrets	Off by default; paid; post-commit for Supabase	CP
B3 Data API	Firebase production-mode rules; App Check	Firebase rules	Prevents client access by default	Test mode allows anyone; App Check "prevents some, but not all"	CP
B4 Agent plane	Sandbox enabled, fail-closed, no unsandboxed retry (managed)	OS sandbox	Limits shell-command blast radius	File tools, MCP, hooks outside; native Windows unsandboxed	CP
B4 Agent plane	Egress allowlist locked by admin (Claude Code, Cursor, Copilot org allowlist)	Network proxy	Limits destinations	Allowlisted hosts accept uploads; MCP traffic not covered	CP
B4 Agent plane	Credential deny/mask with injectHosts; env scrub; Read() deny on secret paths	Agent config	Prevents agent reading secrets	No built-in credential deny list; must enumerate	CP

Boun dary	Control	Enforce ment locus	Verdict	Bypass / limitation	Evid enc e tier
B4 Agent plane	Managed MCP allowlist; read-only project-scoped MCP; manual approval	Agent config + MCP server	Limits MCP exposure	Approval "a guardrail, not a guarantee"; read-only still permits reads	CP
B4 Agent plane	Dev/prod database separation (Replit); data-less branches (Supabase); anonymised branches (Neon)	Platform	Prevents production mutation by agent	Shared staging still destroyable; publish-time structural changes	CP
B4 Agent plane	OIDC federation / short-lived scoped tokens; project-scoped tokens where scoping absent	Cloud IAM / platform	Prevents over-scoped credential reach	Railway has no scoped tokens as of Oct 2026	CP
B4 Agent plane	Provider soft-delete windows	Platform	Limits (recovery)	Credential can purge or wait out	CP
B4 Agent plane	Isolated immutable backups (LAG vault + optional MPA; locked Azure vault + Resource Guard; GCP enforced retention; object lock) with restore drills	Separate account/tenant storage	Limits (recovery)	Minimum retention; account closure; RPO by schedule	CP
B4 Agent plane	Internal registry proxy as sole package source; lockfiles and hash pinning	Egress + CI	Prevents hallucinated package install	Curation quality; Socket free tier warns only on AI-suspected	CP/P ROP
B4 Agent plane	Platform guardrails (Copilot: no default-branch push, approval for Actions, 59-min sessions)	Cloud agent platform	Prevents direct production merge	Repo rulesets incompatible block the agent	CP
B4 Agent plane	Repository config inspection before opening; pinned agent versions above CVE fixes	Process + managed settings	Prevents pre-trust execution	Relies on discipline; new issues possible	CP
Cross - cuttin g	App registry with owner, data class, expiry, processing-activity link	Governance	Enables lifecycle and Art. 24 evidence	Expiry and ROPA-link fields have no precedent	CP/P ROP
Cross - cuttin g	Quarantine / Block kill switch (Power Platform), unpublish, connector revoke	Platform admin	Limits exposure duration	Not available with same granularity on consumer builders	CP
Cross - cuttin g	Outside-in discovery pipeline	Security operations	Detects shadow apps	CT blind for platform subdomains; attribution by content	CP/V R
Cross - cuttin g	Training tied to tool access	HR + IdP	Enables Art. 4 evidence	No outcome evidence	CP/I NF

(d) Rollout phases

P h a s e	Nam e	Win do w	Key actions	Exit criterion	Owner	Evidence
0	Stop the bleeding	Weeks 0-2	Inventory ask; inside-tenant exports; IdP/email/expense signals; outside-in search; team defaults set; Supabase grant, RPC, definer and trigger audit per project before 30 Oct 2026; rotate bundled keys; builder domains in SSE/DLP	Known estate registered; no unauthenticated app with non-public data; no secret key in any bundle	CISO with platform team	Registry v0; discovery report; grant audit

P h a s e	N a m e	W i n d o w	Key actions	Exit criterion	Owner	Evidence
1	Pave d road	Days 30-90	Enterprise tenant with SSO/SCIM; admin-owned connectors; registry schema live; tier policy; IdP proxy with origin validation; OIDC federation; push protection; DPA gap analysis; training tied to access	New apps reach data only via approved paths; every T1+ app has an owner	Platform architect; DPO for DPA	Tenant config export; DPA gap analysis; training report
2	Deterministic gates	Days 90-180	Blocking secrets/SCA/SAST pipeline incl. build-output scan; behavioural matrix per release; managed agent settings; read-only scoped MCP; masked dev branches; isolated immutable backups with drills; retention per sink; LLM gateway retention	Destructive agent action or broken policy cannot reach production unnoticed	Platform engineering; security architecture	Pipeline logs; matrix results; restore RTO/RPO; managed-settings status
3	Run it	Ongoing	Weekly outside-in scan; attestation cadence by tier; quarantine on departure or missed attestation; T0 expiry; honeytokens; annual tabletop per failure mode; quarterly exception review	Unowned apps cease to exist by construction; exceptions trend to zero	Governance board; AI Functional Leads	KPI dashboard; exception register; tabletop records